

Security Operations (SecOps) and Incident Response

Dr. Ruba Alomari

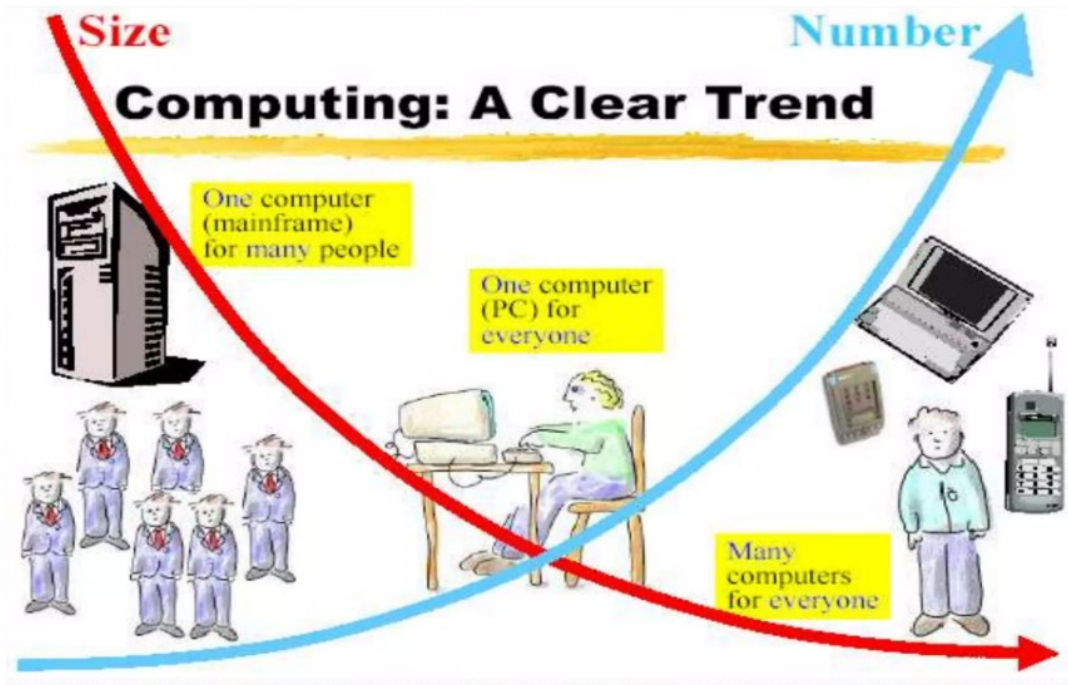
**MITS5600G – Security Policies and Risk
Management**

References

- The material in this lecture note is based on the following books:
- 1. Developing Cybersecurity Programs and Policies, Omar Santo, 4th edition, 2024.
- 2. Security Program and Policies, Sari Greene, 2nd Edition, 2014
- 3. Principles of Incident Response and Disaster Recovery, Michael E. Whitman, Herbert J. Mattord, and Andrew Green 3rd Edition, 2021,
- 4. Management of Information Security, 6th Edition, by Michael E. Whitman, Herbert J. Mattord.

Recall–Last Week–Introduction

- Today, computing devices are omnipresent.
- We are tasked with protecting devices that range from massive cloud-based multiplex systems to tiny handheld devices.



<https://www.slideshare.net/govindraj15/ubiquitous-computing-by-govind-raj>

Recall–Last Week–Physical and Environmental Security

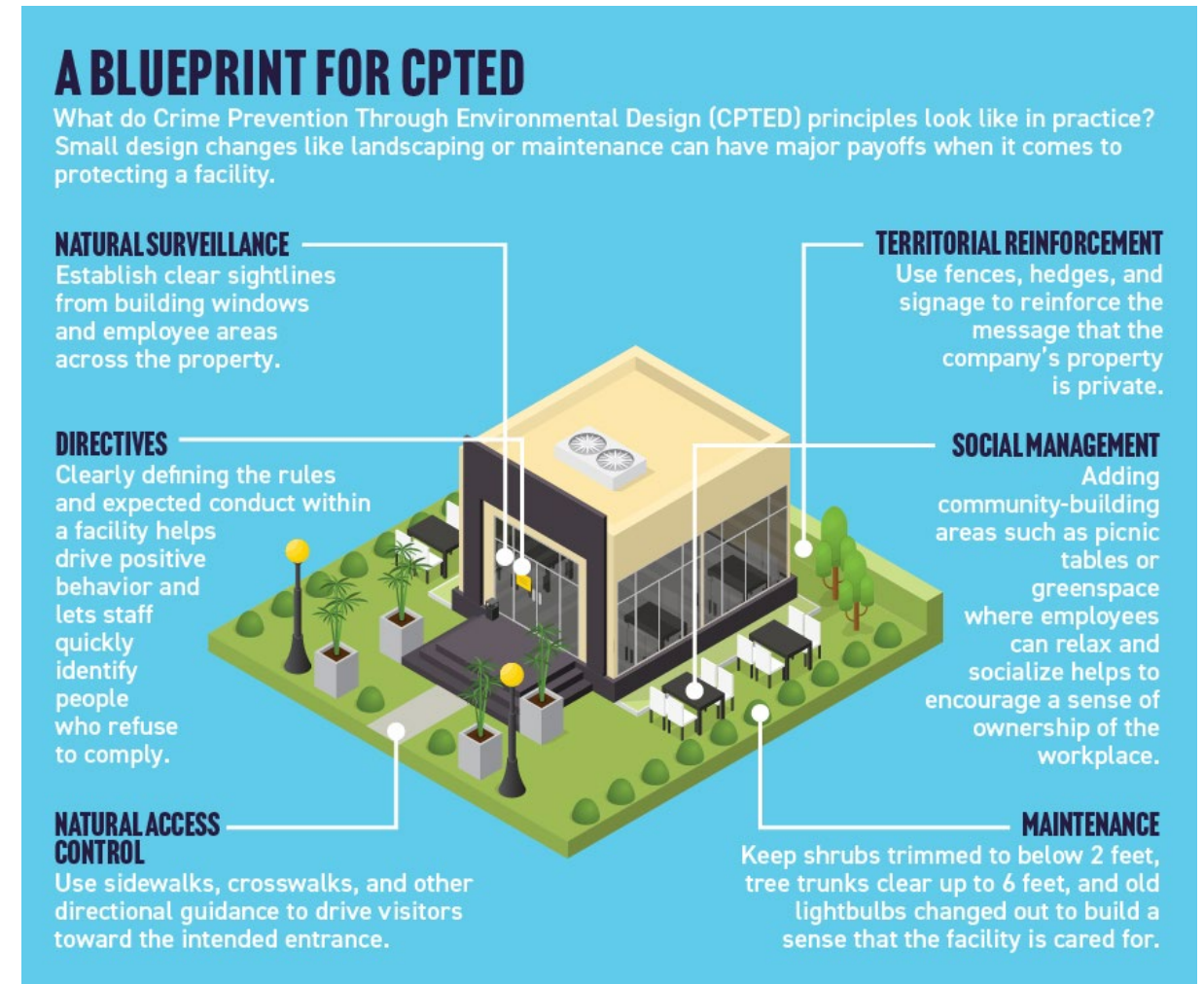
- Protecting Equipment
 - No Power, No Processing?
 - How Dangerous is Fire?
 - What About Disposal?
 - Stop, Thief!



A power line tower is bent to the ground in Moore, Okla. (Holly Bailey / Yahoo News), 2013

Recall–Last Week– Crime Prevention Through Environmental Design

- CPTED (pronounced SEP-ted) has as its basic premise that the proper design and effective use of the physical environment can lead to a reduction in the incidence and fear of crime.
 1. Natural surveillance.
 2. Directives.
 3. Natural access control.
 4. Territorial reinforcement.
 5. Social Management.
 6. Maintenance.



<https://www.asisonline.org/security-management-magazine/articles/2022/05/growing-a-sense-of-ownership-with-cpted/>

Topics

- Security Operations (SecOps)
- Incident Response
- Threat Hunting
- Digital Forensic Analysis

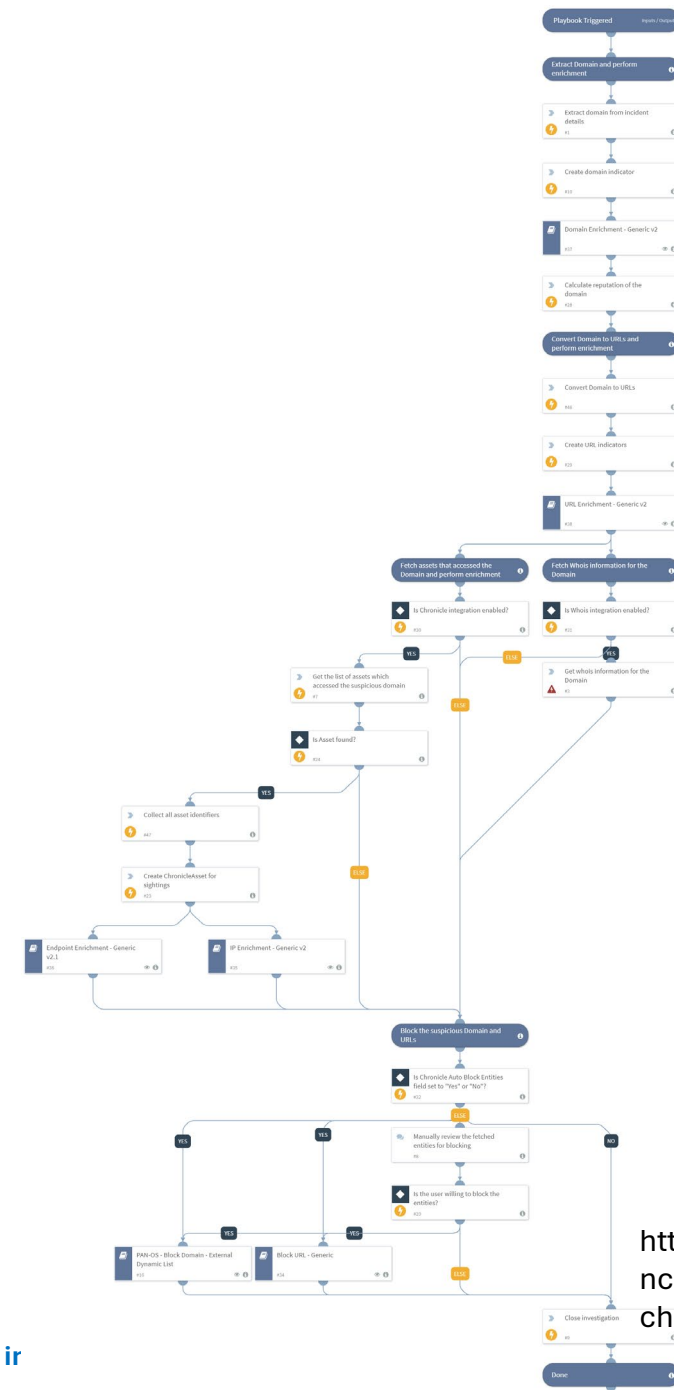
What is Security Operations (SecOps)?

- **SecOps** is the continuous monitoring, detection, investigation, response, and recovery from cybersecurity threats and incidents.
- It refers to the practical, operational side of defending digital infrastructure.
- Security Operations is typically performed by a Security Operations Center (SOC).



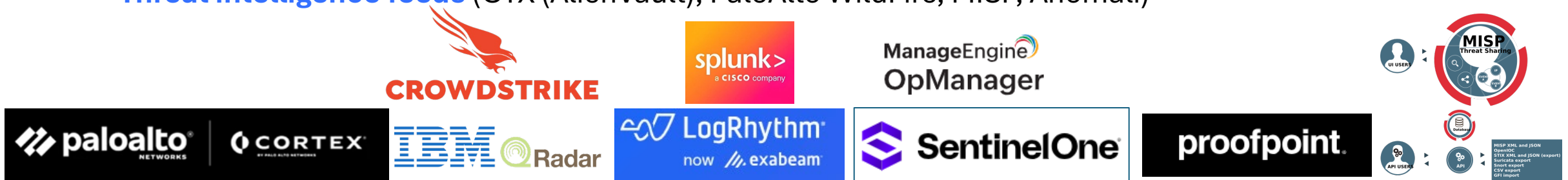
What Does SecOps Cover?

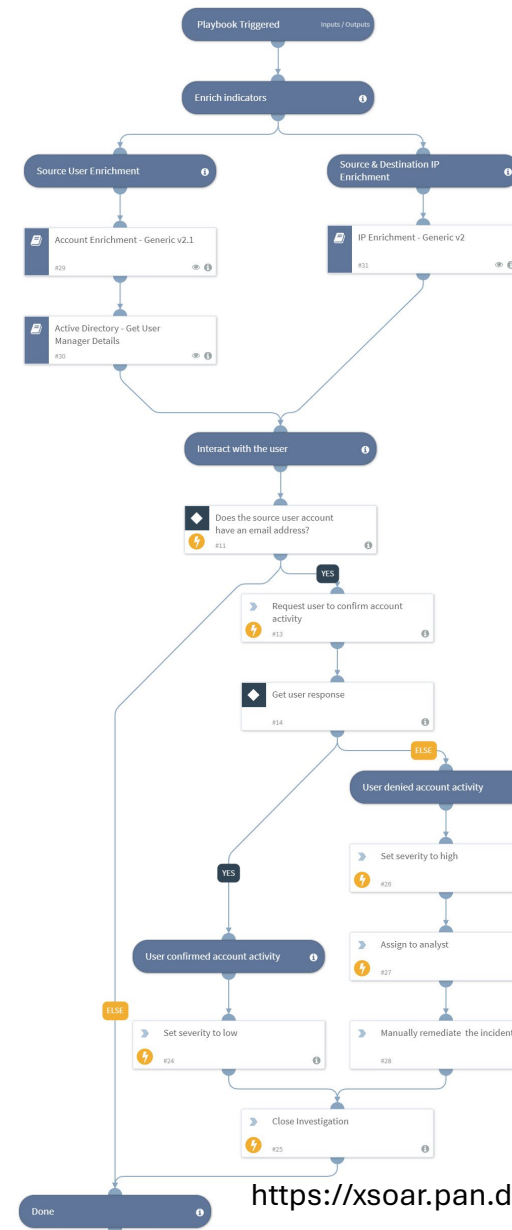
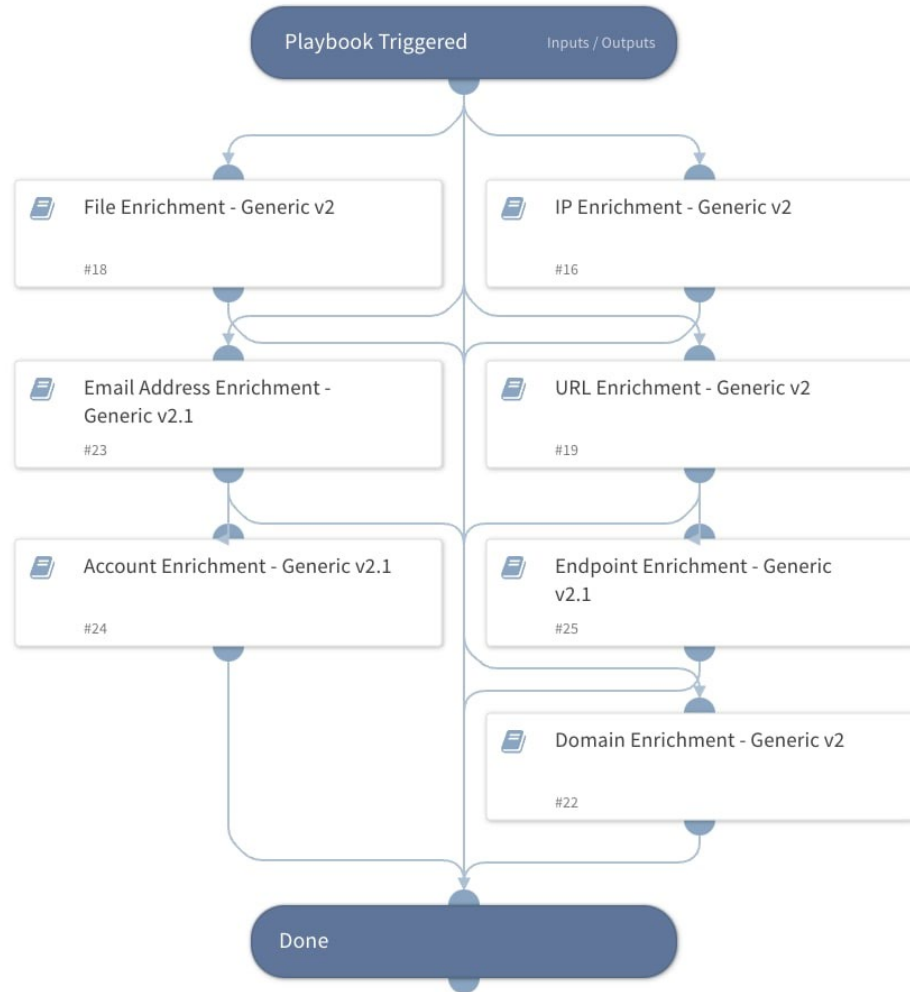
- Core components of SecOps:
 - Security Monitoring
 - Log and Event Analysis
 - Threat Detection
 - Incident Response
 - Digital Forensics
 - Reporting and Documentation
 - Threat Hunting
 - Vulnerability Management
 - Threat Intelligence



Tools of the Trade - SecOps

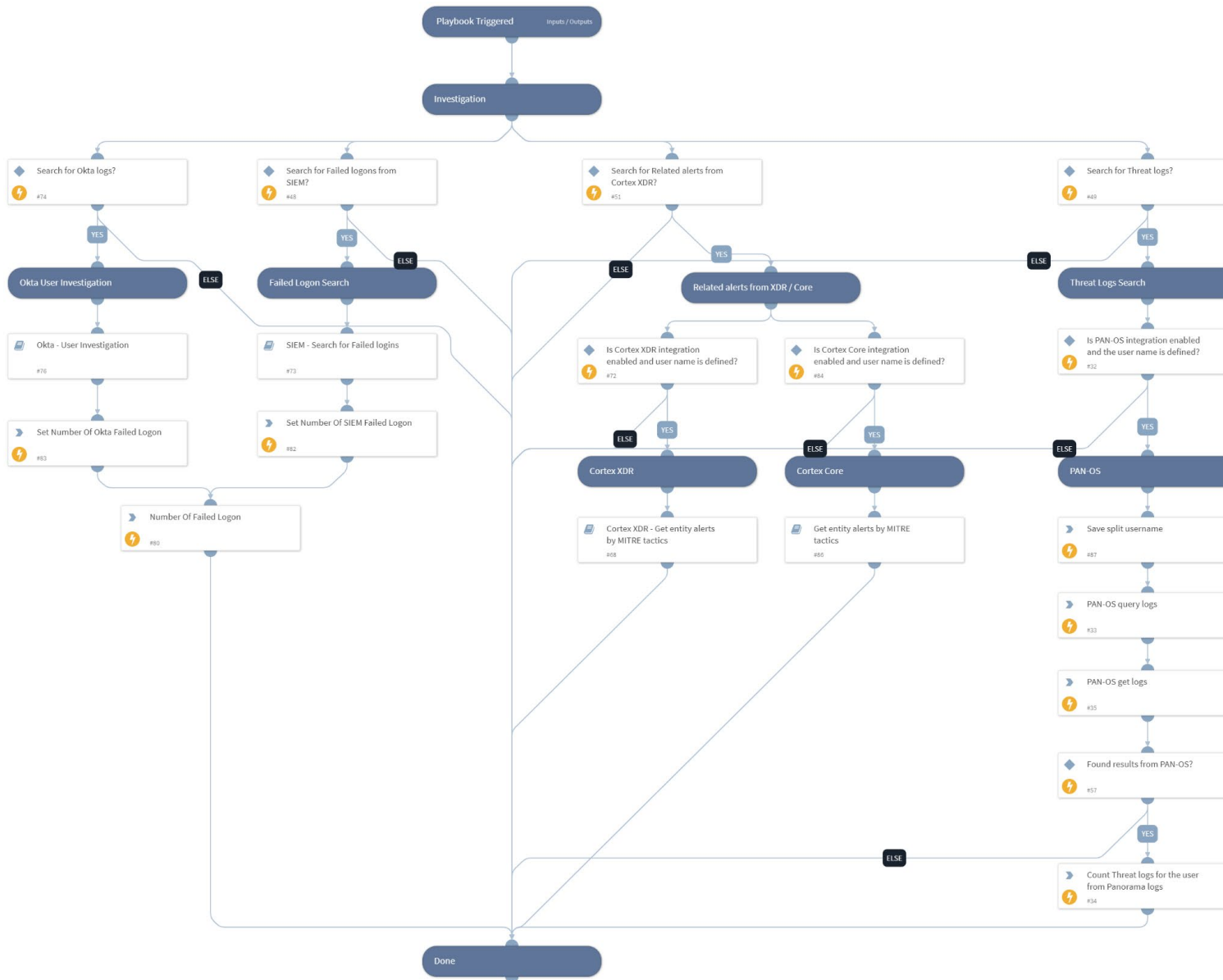
- **SIEM - Security Information and Event Management** (e.g., Splunk, QRadar, LogRhythm, Microsoft Sentinel)
- **EDR - Endpoint Detection and Response** (e.g., CrowdStrike Falcon, SentinelOne, Sophos, TrendMicro, Microsoft Defender, Palo Alto Cortex XDR)
 - XDR (Extended Detection and Response) platforms correlate telemetry across endpoints, networks, cloud services, and identities.
- **SOAR – Security Orchestration, Automation, and Response** platforms for automated response (PaloAlto Cortex XSOAR, Splunk SOAR/Phantom)
- **Network monitoring tools** (ManageEngine, SolarWinds)
- **Threat intelligence feeds** (OTX (AlienVault), PaloAlto WildFire, MISP, Anomali)





This playbook investigates an access incident by gathering user and IP information.

The playbook then interacts with the user that triggered the incident to confirm whether or not they initiated the access action.



This playbook performs an investigation on a specific user, using queries and logs from SIEM, Identity management systems, XDR, and firewalls.

Topics

- Security Operations (SecOps)
- Incident Response
- Threat Hunting
- Digital Forensic Analysis

Organizational Incident Response /1

- Incidents drain resources, can be very expensive, and can divert attention from the business of doing business.
- Even the best prevention strategy isn't always enough, which is why preparation is key.
- Incident preparedness includes having policies, strategies, plans, and procedures.
- Organizations should create **written guidelines**, have **supporting documentation** prepared, **train personnel**, and **engage in mock exercises**.



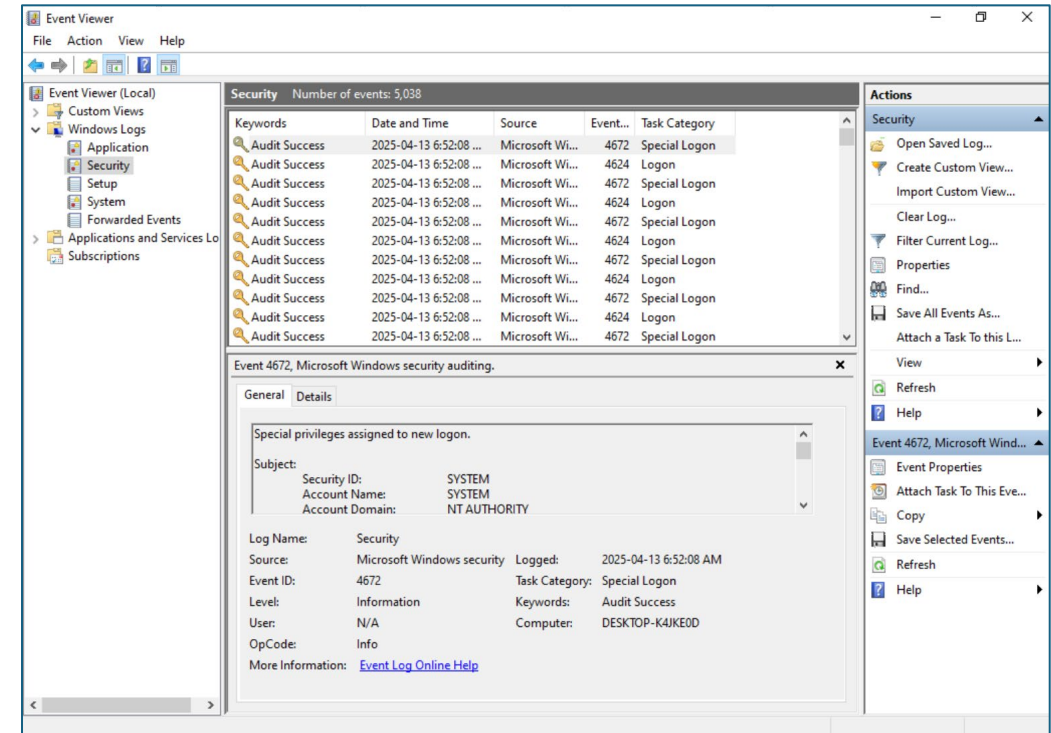
Organizational Incident Response /2

- Benefits of having a practiced incident response capability include
 - Minimization of loss or damage
 - Protection of affected parties
 - Preservation of evidence
 - Compliance with laws, regulations, and standards that require or imply incident response, breach notification, evidence preservation, and security controls.
 - Integration of lessons learned
 - Lower future risk and exposure
 - Calm and systematic response



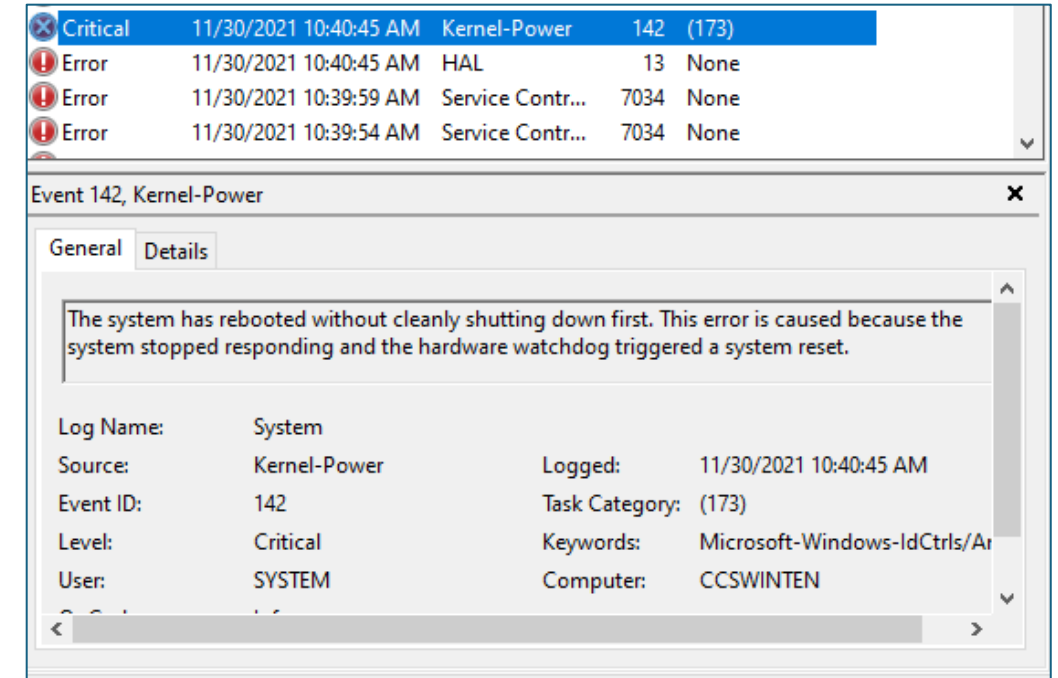
Cybersecurity Events and Adverse Events

- **Cybersecurity event:** Any observable occurrence in a system or network
 - A user connects to a file share
 - A server receives a request for a web page
 - A user sends an email
- Event ≠ Incident



Cybersecurity Events and Adverse Events

- **Adverse events:** Events with **negative** consequences
 - A system crashes
 - Unauthorized access of sensitive data
 - Malware destroys data on an end-user client system



What is a Cybersecurity Incident?

- A cybersecurity incident is an adverse event that **threatens business security** and/or **disrupts service**. It is related to the loss of confidentiality, integrity, or availability (CIA).
- Examples:
 - An attacker sends a crafted packet to a router and causes a denial-of-service (**DoS**) condition.
 - An attacker compromises a point-of-sale (POS) system and **steals credit card information**.
 - An attacker compromises a hospital database and **steals thousands of health records**.
 - An attacker installs **ransomware** in a critical server and encrypts all the files.

Event	Incident
User logs in	No
Failed login	Usually no
500 failed logins in 2 minutes	Possibly
Successful brute-force compromise	Yes

Types of Incidents

- Each **major type** of incident that can be foreseen should have a separate containment strategy defined as part of the organization's planning process.
- Common incident types:
 - **Denial of Service (DoS) Attack**
 - **Malware**
 - **Ransomware**
 - **Data Breach**
 - **Intentional Unauthorized Access or Use**
 - **Inappropriate Use**
 - **Insider Threat**
 - **Supply Chain Compromise**
 - **Cloud Security Incident**
 - **Lost or Stolen Devices**

Denial of Service (DoS) Attacks

- **Denial of Service (DoS) attacks** prevent or impair the normal authorized functionality of the organization's networks, systems, or applications.
- Recall Week 3 – DDoS Attacks (Direct, Reflected, and Amplification DDoS attacks)

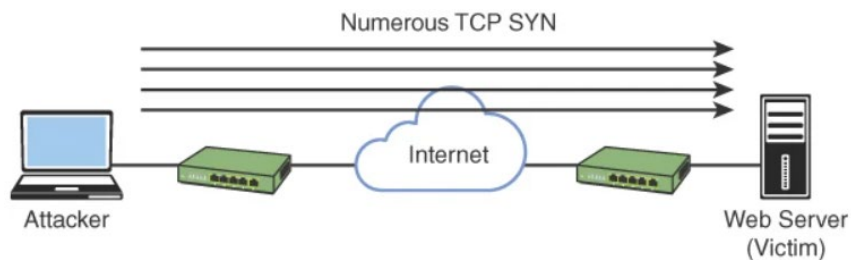


FIGURE 3-4 A Direct DDoS Attack

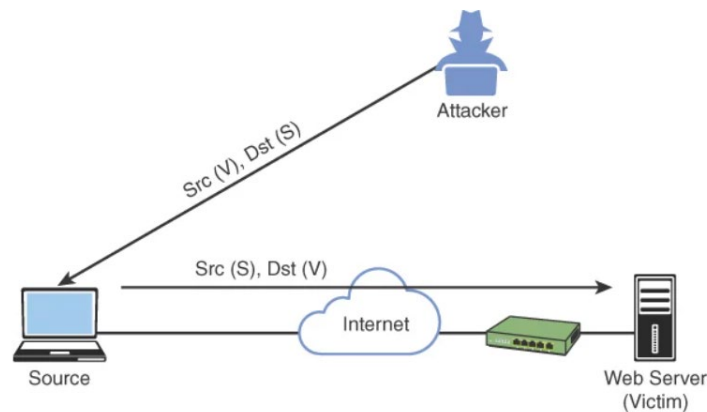


FIGURE 3-5 Reflected DDoS Attack

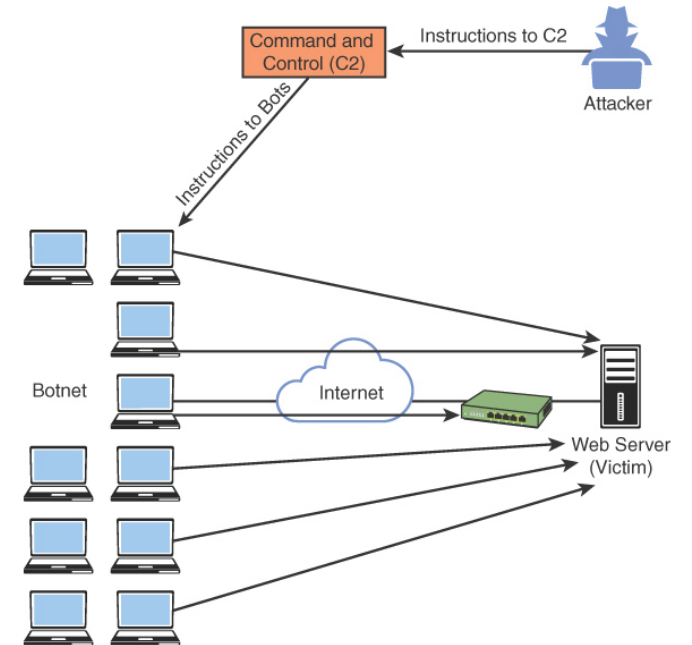
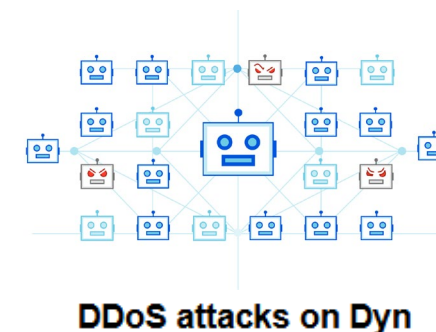


FIGURE 3-6 A Botnet and a Command and Control System

Example – Dyn DDoS Attack (2016)

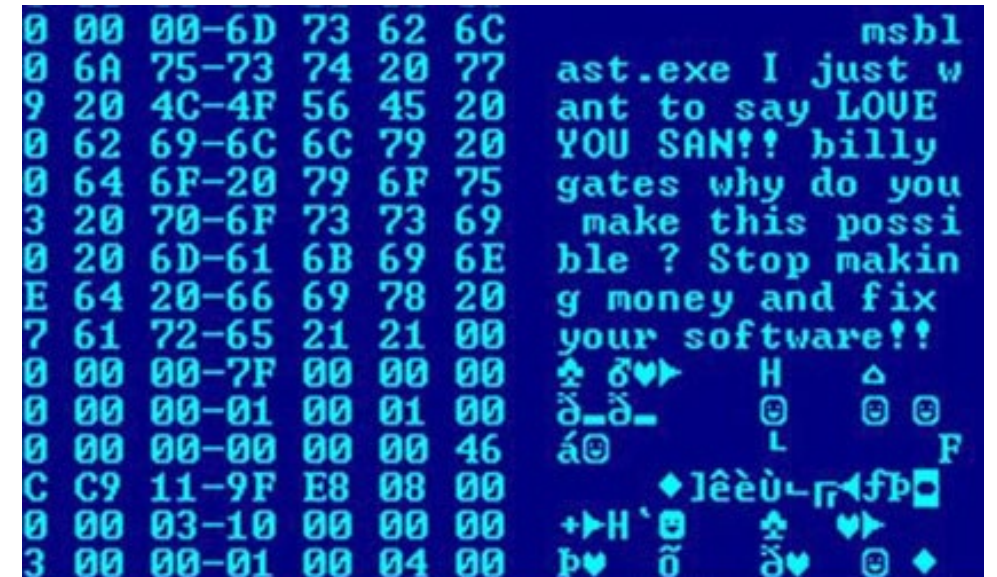
- On October 21, 2016, DNS provider Dyn was targeted by a massive Distributed Denial-of-Service (DDoS) attack.
- The attack disrupted access to major websites, including Netflix, Twitter, Spotify, and Reddit.
- Attackers used the Mirai botnet.
- Thousands of compromised IoT devices (e.g., cameras) flooded Dyn's DNS infrastructure with traffic.
- Security analysts identified a large-scale DDoS attack originating from many distributed IP addresses:
 - Traffic filtering and mitigation services were activated.
 - Malicious traffic was blocked where possible.
 - DNS services were gradually restored.
 - Traffic was rerouted and mitigated.



https://en.wikipedia.org/wiki/DDoS_attacks_on_Dyn

Malware

- **Malware**: Computer software specifically designed to perform malicious or unwanted actions and attack a system.
- Designed to steal information, do damage, or deny service to the target systems.
 - Virus, Ransomware, Worm, Trojan horse, Backdoor, Rootkit.

A hex dump of the Blaster worm's payload. The left column shows hexadecimal values, and the right column shows the corresponding ASCII text. The text is a message from the worm's programmer to Microsoft co-founder Bill Gates, dated 2003. The message reads: "ast.exe I just want to say LOVE YOU SAN!! billy gates why do you make this possible ? Stop making money and fix your software!!". Below the text are several lines of ASCII art, including a heart, a diamond, and a square, and a signature "H L F".

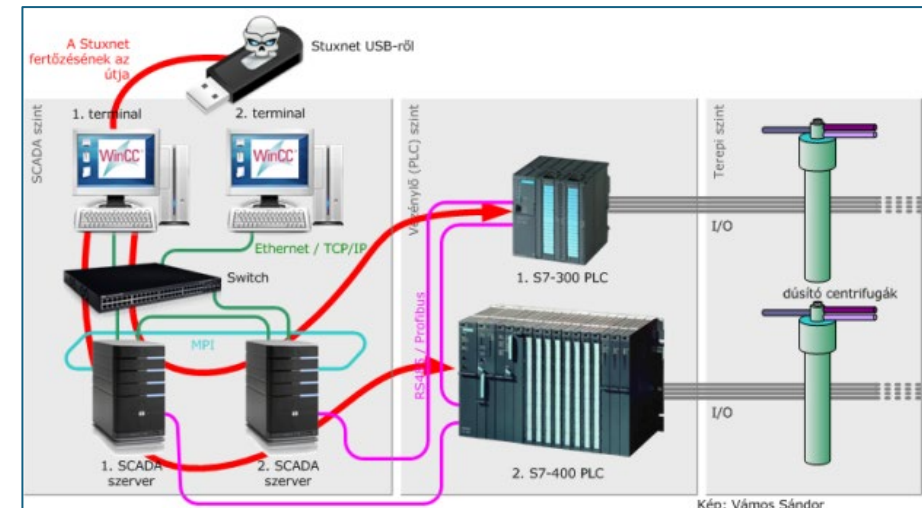
```
00 00 00-6D 73 62 6C mshl
00 6A 75-73 74 20 77 ast.exe I just w
19 20 4C-4F 56 45 20 ant to say LOVE
00 62 69-6C 6C 79 20 YOU SAN!! billy
00 64 6F-20 79 6F 75 gates why do you
13 20 70-6F 73 73 69 make this possi
00 20 6D-61 6B 69 6E ble ? Stop makin
E6 64 20-66 69 78 20 g money and fix
17 61 72-65 21 21 00 your software!!
00 00 00-7F 00 00 00  H  L
00 00 00-01 00 01 00  H  L
00 00 00-00 00 00 46  H  L
C9 11-9F E8 08 00  H  L
00 00 03-10 00 00 00  H  L
13 00 00-01 00 04 00  H  L
```

Hex dump of the **Blaster** worm, showing a message left for Microsoft co-founder Bill Gates by the worm's programmer, **2003**

https://en.wikipedia.org/wiki/Timeline_of_computer_viruses_and_worms

Example – Stuxnet (2010)

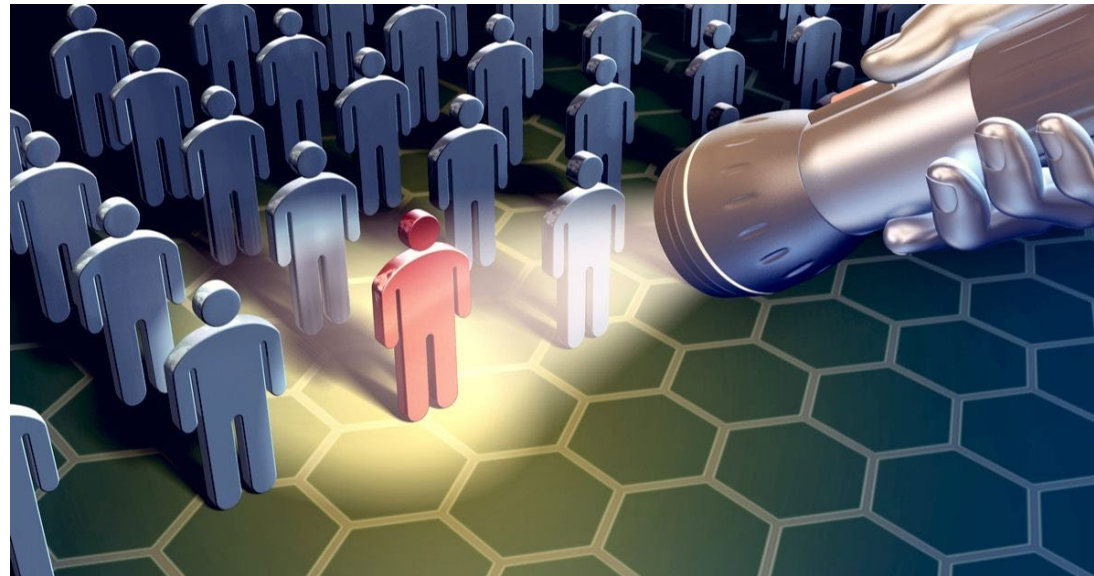
- Stuxnet was a highly sophisticated malware discovered in 2010.
- It targeted Iran's nuclear enrichment facility at Natanz.
- Widely believed to have been developed by the United States and Israel.
- Considered the first known cyberweapon designed to cause physical damage.
- Target:
 - Siemens Step7 Industrial Control Systems (ICS).
 - Programmable Logic Controllers (PLCs) controlling uranium enrichment centrifuges.
- Objective:
 - Disrupt Iran's nuclear enrichment program.
 - Cause physical damage while avoiding detection.



https://commons.wikimedia.org/wiki/File:StuxNet_1.png

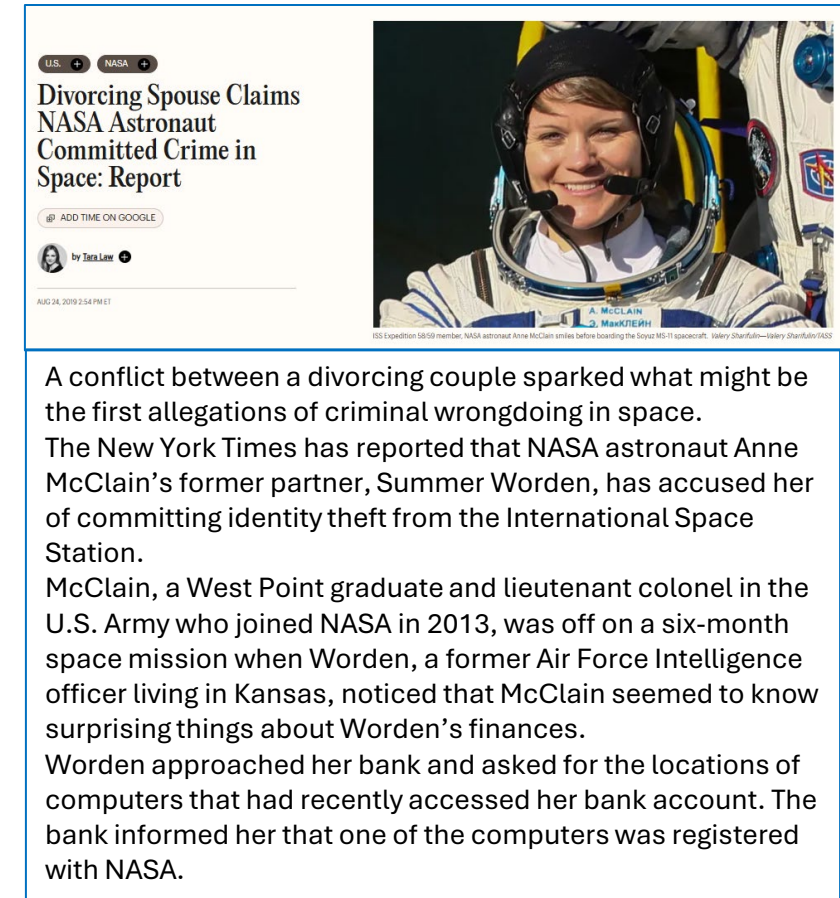
Intentional Unauthorized Access or Use /1

- **Intentional Unauthorized Access (UA):** Occurs when an **intruder** or **insider** gains logical or physical access without permission to a network, system, application, data, or other resource.



Suspected “First Crime in Space” Unauthorized Access

- NASA astronaut Anne McClain was accused by her ex-partner (Summer Worden) of accessing a personal bank account without authorization from the International Space Station.
- The access was traced to a NASA-registered computer, raising concerns about misuse of authorized systems for personal purposes.
- NASA and federal investigators concluded that Anne McClain acted within her legal rights.
- She had prior authorization to access the bank account, and there was no criminal intent or breach.
- **Jurisdiction in space** (U.S. law applies to U.S. astronauts on the ISS).
 - Legal frameworks for future space missions and stations.



<https://time.com/5660705/divorce-nasa-crime-space/>

Inappropriate Use /1

- **Inappropriate Usage (IU):** Occurs when an **authorized user** performs actions that violate company policy, agreement, law, or regulation.
- Traditionally, IU incidents are identified by IT personnel but are regulated and controlled by management.
- Examples:
 - Downloading music or video in violation of copyright laws
 - An employee or contractor viewing a patient's medical records or a bank customer's financial records purely for curiosity's sake
 - An employee or contractor sharing information with unauthorized users.



Inappropriate Use /2

**Archives**
U.S. Department of Justice

Our Offices | Find Help | Contact Us

Search

About | News | Documents | Internships | FOIA | Contact | Information for Journalists

Justice.gov > Office of Public Affairs > News > Press Releases > Wells Fargo Agrees To Pay \$3 Billion To Resolve Criminal and Civil Investigations Into Sales Practices Involving The Opening of Millions of Accounts Without Customer Authorization

This is archived content from the U.S. Department of Justice website. The information here may be outdated and links may no longer function. Please contact webmaster@usdoj.gov if you have any questions about the archive site.

PRESS RELEASE

Wells Fargo Agrees to Pay \$3 Billion to Resolve Criminal and Civil Investigations into Sales Practices Involving the Opening of Millions of Accounts without Customer Authorization

Friday, February 21, 2020

For Immediate Release
Office of Public Affairs

In 2020, Wells Fargo paid a \$3 billion penalty—the largest fine against a bank for defrauding its own customers—for opening millions of unauthorized accounts over 14 years.

Health

Snooping celebrity medical records cases settled

The Associated Press · Posted: Jul 08, 2011 9:51 AM EDT | Last Updated: July 8, 2011



Years after hospital employees were accused of snooping into the medical records of celebrity patients, UCLA Health System agreed to pay an \$865,000 US settlement for potential violations of federal privacy laws.

The settlement that UCLA reached with federal regulators Wednesday did not name the stars involved and did not require the hospital system to admit liability.



A former UCLA employee pleaded guilty to selling information to a tabloid from the files of Britney Spears, Farrah Fawcett and other high-profile celebrities. (Tony Avelar/AP)

In 2011, UCLA Health System paid \$865,000 to settle federal privacy violations after employees snooped into celebrity medical records, including those of Britney Spears and Farrah Fawcett.

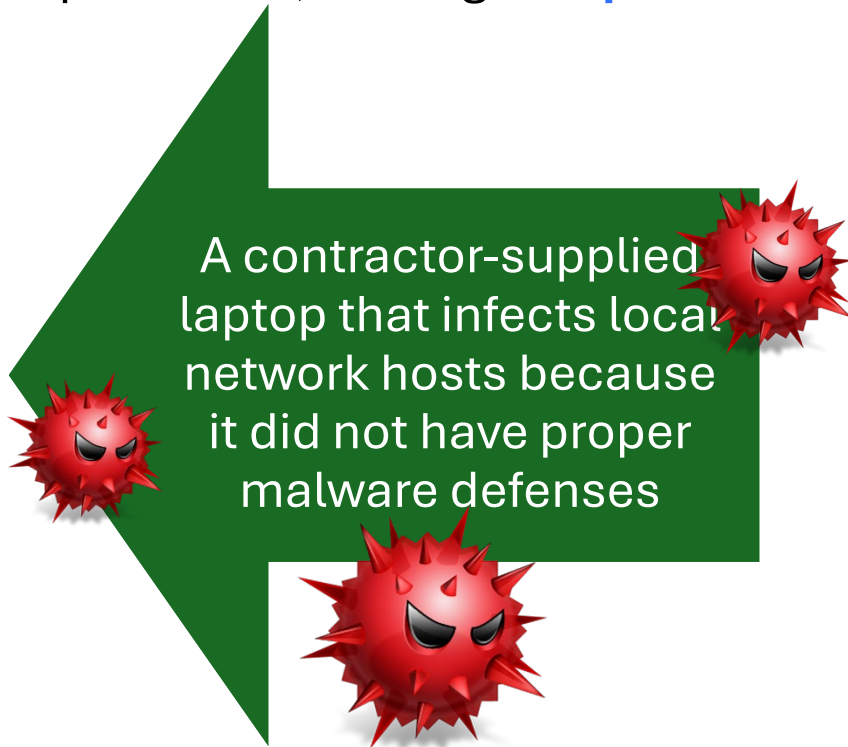
UA vs. IU – Example

- Attempting to access unauthorized information or to escalate one's access privileges would be a UA violation.
- Whereas, attempting to download, install, or use software, hardware, or services in violation of organizational policy constitutes inappropriate use.



Incident Severity Levels

- Not all incidents are equal in severity.
- The incident definition should include **severity levels** based on the operational, reputational, and legal **impact** to the organization.



Severity Level = 1

- Level 1 incidents are defined as those that could cause **significant harm** to the business, customers, or the public and/or are in violation of corporate law, regulation, or contractual obligation.

Severity Level = 1	
Explanation	Level 1 incidents are defined as those that could cause significant harm to the business, customers, or the public and/or are in violation of corporate law, regulation, or contractual obligation.
Required response time	Immediate
Required internal notification	Chief executive officer Chief operating officer Legal counsel Chief information security officer Designated incident handler
Examples	Compromise or suspected compromise of protected customer information Theft or loss of any device or media on any device that contains legally protected information A denial of service attack Identified connection to “command and control” sites Compromise or suspected compromise of any company website or web presence Notification by a business partner or vendor of a compromise or potential compromise of a customer or customer-related information Any act that is in direct violation of local, state, or federal law or regulation

Severity Level = 2

- Level 2 incidents are defined as compromise of or unauthorized access to **noncritical systems or information**; detection of a precursor to a focused attack; a believed threat of an imminent attack; or any act that is a **potential** violation of law, regulation, or contractual obligation.

Severity Level = 2	
Explanation	Level 2 incidents are defined as compromise of or unauthorized access to noncritical systems or information; detection of a precursor to a focused attack; a believed threat of an imminent attack; or any act that is a potential violation of law, regulation, or contractual obligation.
Required response time	Within four hours
Required internal notification	Chief operating officer Legal counsel Chief information security officer Designated incident handler
Examples	Inappropriate access to legally protected or proprietary information Malware detected on multiple systems Warning signs and/or reconnaissance detected related to a potential exploit Notification from a third party of an imminent attack

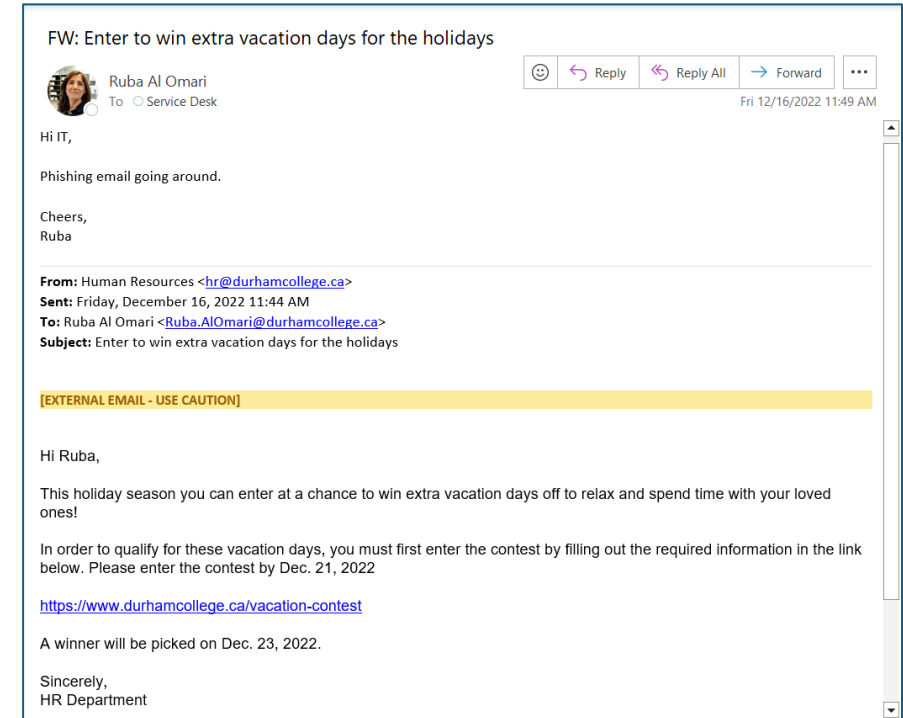
Severity Level = 3

- Level 3 incidents are defined as situations that **can be contained and resolved** by the information system custodian, data/process owner, or HR personnel. There is no evidence or suspicion of harm to customer or proprietary information, processes, or services.

Severity Level = 3	
Explanation	Level 3 incidents are defined as situations that can be contained and resolved by the information system custodian, data/process owner, or HR personnel. There is no evidence or suspicion of harm to customer or proprietary information, processes, or services.
Required response time	Within 24 hours
Required internal notification	Chief information security officer Designated incident handler
Examples	Malware detected and/or suspected on a workstation or device, with no external connections identified User access to content or sites restricted by policy User's excessive use of bandwidth or resources

How Are Incidents Reported? /1

- There should be a **simple, easy-to-use mechanism** that can be used by all employees to report the discovery of an incident.
- Employees should be required to report all actual and suspected incidents.
- The employee who discovers an incident should not be expected to assign a severity level, because they may not be trained or an IT technician.
- Employees must be assured that even if they were to report a perceived incident that ended up being a **false positive**, they would not be ridiculed or met with annoyance.



Incident Management Planning and Preparation /1

- The organization should plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.

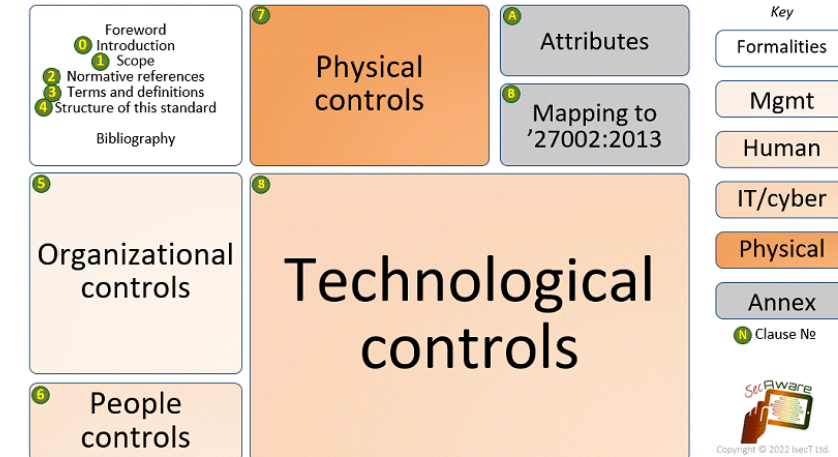
5.24 Information security incident management planning and preparation

Control type	Information security properties	Cybersecurity concepts	Operational capabilities	Security domains
#Corrective	#Confidentiality #Integrity #Availability	#Respond #Recover	#Governance #Information_security_event_management	#Defence

Control

The organization should plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.

ISO/IEC 27002:2022



ISO 27002-2022 Incident Response and Handling

Incident Management Planning and Preparation /2

- **5.24 Information security incident management planning and preparation:** The organization should plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.
- **5.25 Assessment and decision on information security events:** The organization should assess information security events and decide if they are to be categorized as information security incidents.
- **5.26 Response to information security incidents:** Information security incidents should be responded to in accordance with the documented procedures.
- **5.27 Learning from information security incidents:** Knowledge gained from information security incidents should be used to strengthen and improve the information security controls.
- **5.28 Collection of evidence:** The organization should establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.

What is an IR Plan?

- An incident response plan (IRP) is a roadmap, guidance, and instructions related to Preparation, Detection and Analysis, Containment, Eradication, and Recovery, and Post-incident Activity.

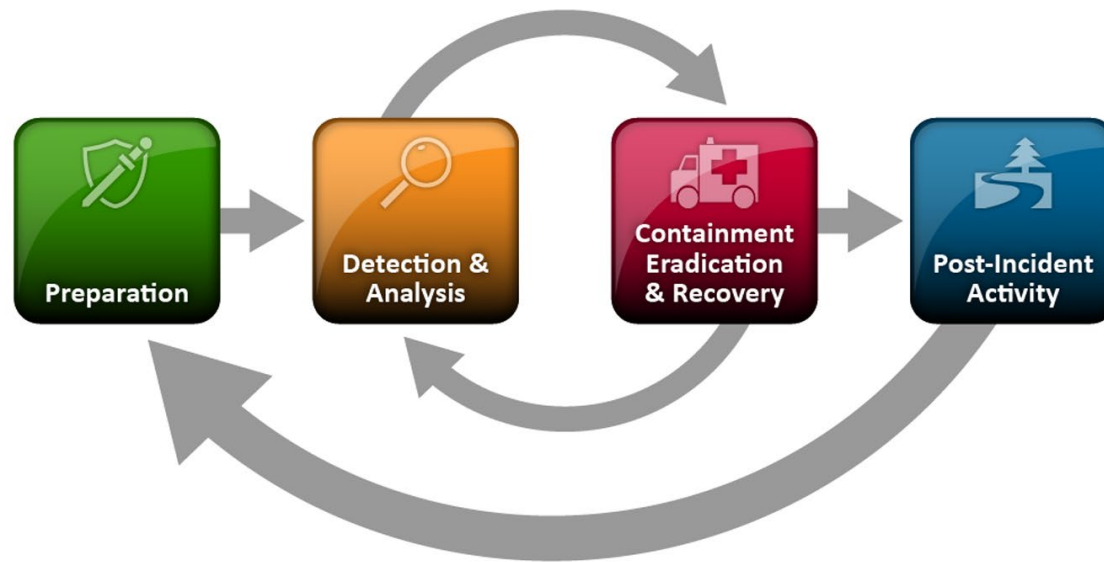


Fig. 1. Previous incident response life cycle model

NIST Incident Response Cycle

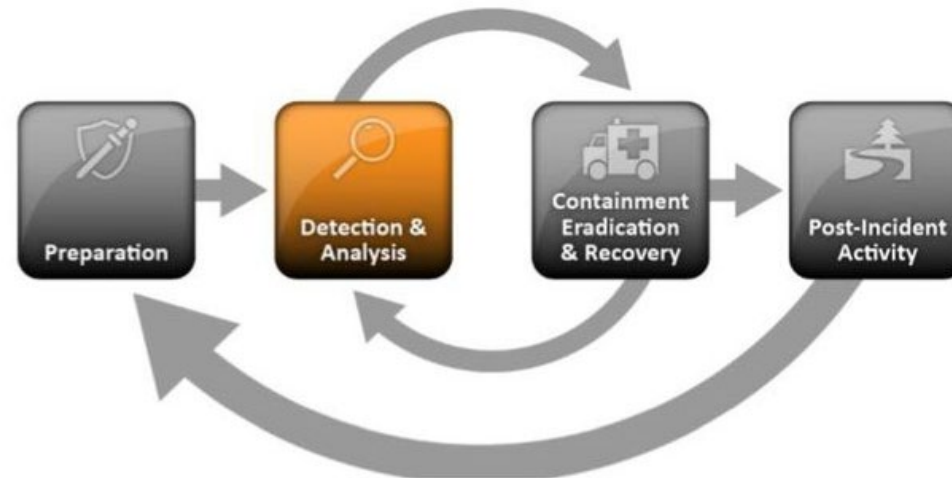
Preparation

- Preparation includes creating and training the incident response **team**, as well as deploying the necessary **tools** and resources to successfully investigate and resolve cybersecurity incidents.
- The preparation phase also includes the following tasks:
 1. Creating processes for incident handling
 2. Making sure the organization has appropriate incident analysis hardware and software as well as incident mitigation software
 3. Creating risk assessment capabilities in the organization
 4. Making sure the organization has appropriately deployed host security, network security, and malware prevention solutions
 5. Developing user awareness training



Detection & Analysis

- Detection and analysis include establishing processes and a knowledge base to accurately detect and assess **precursors** and **indicators**.
 - One of the most challenging phases.



Precursors

- A precursor is a **signal** or **warning** that an incident may occur in the future.

Precursor	Response
Reconnaissance activity to determine which attacks would be effective; often, this is a lower volume of the traffic that will be used in the attack.	Attempt to block the attack by quickly altering the security posture—for example, altering firewall rule sets to block a particular protocol from being used or to protect a vulnerable host.
Newly released DoS tool.	Investigate the new tool and, if possible, alter security controls so that the tool will not be effective against the organization.

Example - DoS Precursors

Indicators of Compromise

- An indicator of compromise (IoC) is **evidence** or **activity** that signals an incident may have occurred or may be occurring now.

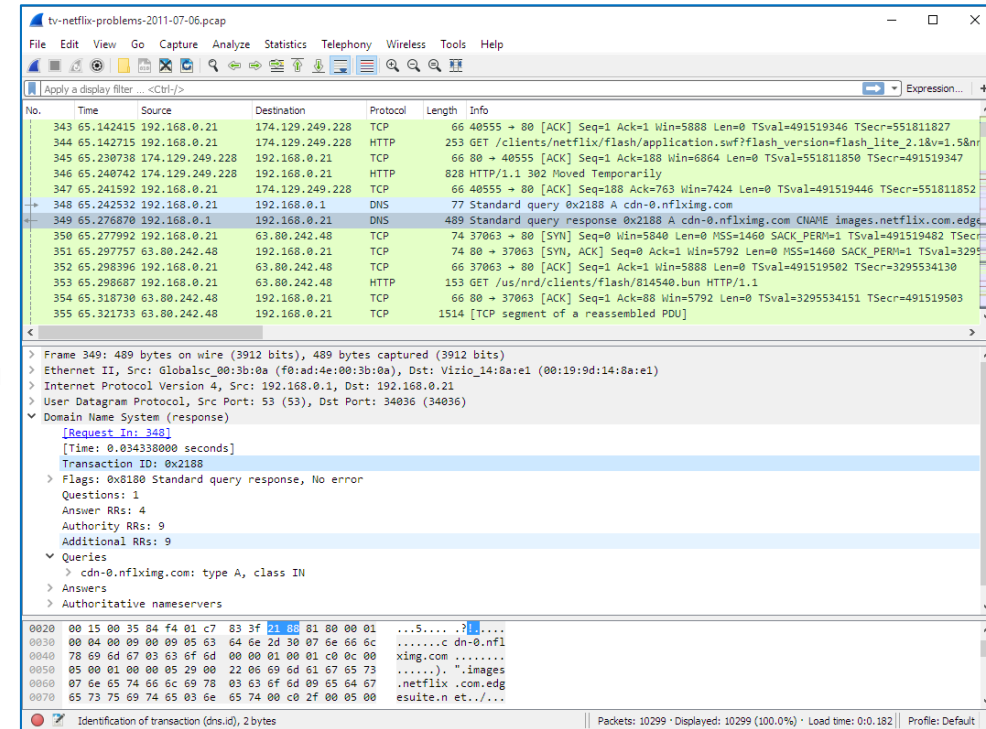
Malicious Action	Indicators
Network-based DoS attack against a network	• User reports of system and network unavailability • Unexplained connection losses • Network intrusion detection alerts • Increased network bandwidth utilization • Asymmetric network traffic pattern (large amount of traffic entering the network, little traffic leaving the network) • Packets with unusual source addresses • Packets with nonexistent destination addresses

Example - DoS Indicators

Detection & Analysis – NIST Recommendations /1

- NIST provides various recommendations for making incident analysis easier and more effective:

1. Profile networks and systems
2. Understand normal behaviors
3. Create a log retention policy
4. Perform event correlation
5. Maintain and use a knowledge base of information
6. Use Internet search engines for research
7. Run packet sniffers to collect additional data
8. Filter the data



Detection & Analysis – NIST Recommendations /2

- Continued:

- 9. Seek assistance from others



- 10. Know the different types of attacks and attack vectors

- 11. Develop processes and procedures to recognize the signs of an incident

- 12. Understand the sources of precursors and indicators

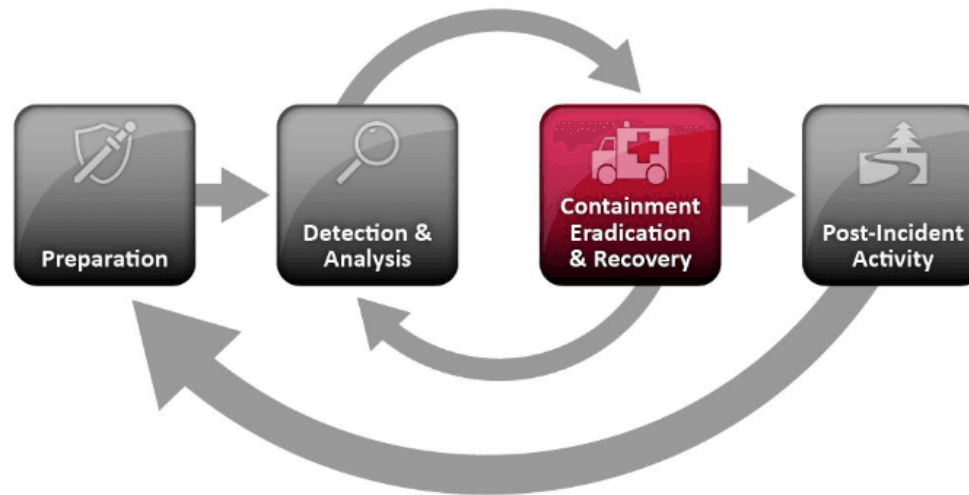
- 13. Create appropriate incident documentation capabilities and processes

- 14. Create processes to effectively prioritize security incidents

- 15. Create processes to effectively communicate incident information (internal and external communications)

Containment

- Containment includes taking the steps necessary to **prevent the incident from spreading**, and as much as possible limit the potential for further damage.



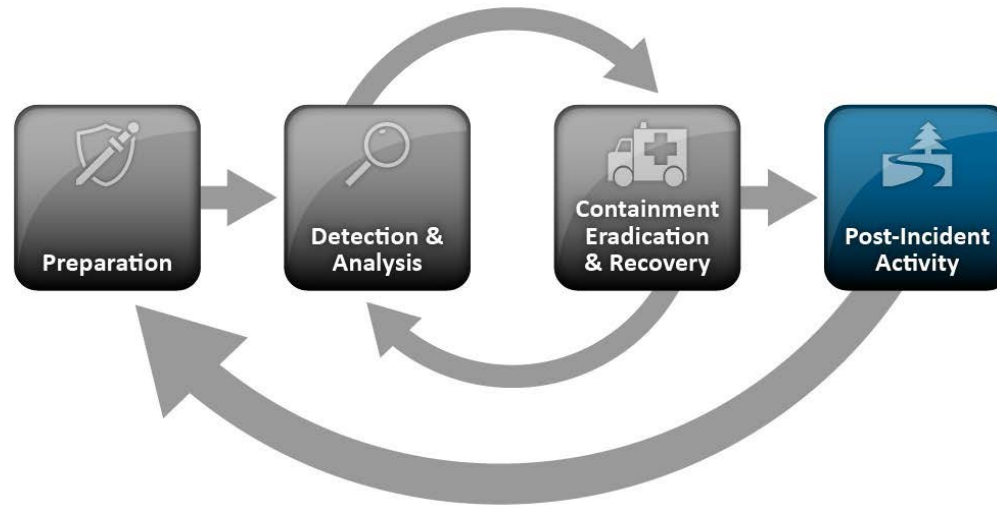
Eradication and Recovery

- Eradication and recovery include the **elimination** of the components of the incident (for example, malicious code, compromised passwords), addressing the vulnerabilities related to the exploit or compromise, and **restoring** normal operations.



Post-Incident /1

- Post-incident activity includes **lessons learned**, how to use collected incident data, and **evidence retention**.
- Documentation and evidence-handling requirements include the recording of facts, observations, participants, actions taken, forensic analysis, and evidence chain of custody.



Post-Incident /2

- Preserve chain of custody if legal proceedings are possible.

Property Record Number: _____

Anywhere Police Department
EVIDENCE CHAIN OF CUSTODY TRACKING FORM

Case Number: _____ Offense: _____
Submitting Officer: (Name/ID#) _____
Victim: _____
Suspect: _____
Date/Time Seized: _____ Location of Seizure: _____

Description of Evidence		
Item #	Quantity	Description of Item (Model, Serial #, Condition, Marks, Scratches)

Chain of Custody				
Item #	Date/Time	Released by (Signature & ID#)	Received by (Signature & ID#)	Comments/Location

APD_Form_#PE003_v.1 (12/2012) Page 1 of 2 pages (see back)

Technical Working Group on Biological Evidence Preservation. *The Biological Evidence Preservation Handbook: Best Practices for Evidence Handlers*. U.S. Department of Commerce, National Institute of Standards and Technology. 2013.

EVIDENCE CHAIN-OF-CUSTODY TRACKING FORM
(Continued)

Chain of Custody				
Item #	Date/Time	Released by (Signature & ID#)	Received by (Signature & ID#)	Comments/Location

Final Disposal Authority	
Authorization for Disposal Item(s) #: _____ on this document pertaining to (suspect): _____ (s) are no longer needed as evidence and is/are authorized for disposal by (check appropriate disposal method) ☐ Return to Owner ☐ Auction/Destroy/Divert Name & ID# of Authorizing Officer: _____ Signature: _____ Date: _____	
Witness to Destruction of Evidence Item(s) #: _____ on this document were destroyed by Evidence Custodian _____ ID#: _____ in my presence on (date) _____ Name & ID# of Witness to destruction: _____ Signature: _____ Date: _____	
Release to Lawful Owner Item(s) #: _____ on this document was/were released by Evidence Custodian _____ ID#: _____ to _____ Name: _____ Address: _____ City: _____ State: _____ Zip Code: _____ Telephone Number: (____) _____ Under penalty of law, I certify that I am the lawful owner of the above item(s). Signature: _____ Date: _____ Copy of Government-issued photo identification is attached. ☐ Yes ☐ No	
This Evidence Chain-of-Custody form is to be retained as a permanent record by the Anywhere Police Department.	

APD_Form_#PE003_v.1 (12/2012) Page 2 of 2 pages (see front)

Technical Working Group on Biological Evidence Preservation. *The Biological Evidence Preservation Handbook: Best Practices for Evidence Handlers*. U.S. Department of Commerce, National Institute of Standards and Technology. 2013.

<https://www.nist.gov/document/sample-chain-custody-formdocx>

Post-Incident /3

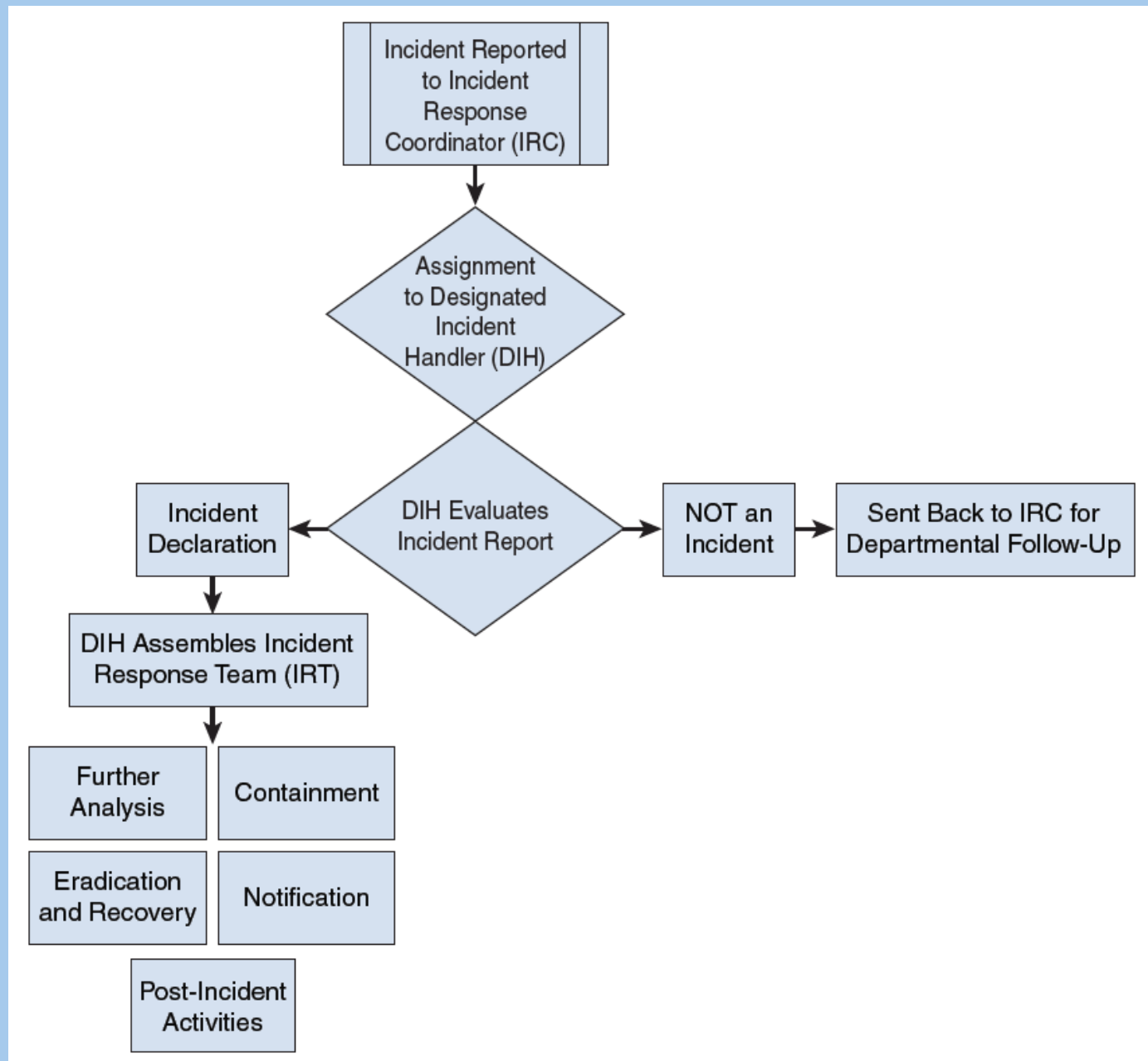
- **Key Question:** Who needs to know, what must be reported, and how quickly must notification occur?
- Notify affected individuals when a breach poses a real risk of significant harm. Examples:
 - PIPEDA may require notification to:
 - Affected individuals
 - Privacy Commissioner of Canada
 - Provincial privacy laws may impose additional obligations.
 - PHIPA includes specific reporting requirements for health information breaches.
- Maintain breach records and document all notification activities.

Post-Incident – Questions

- NIST Special Publication 800-61 r2 includes several questions that can be used as guidelines during the lessons learned meeting(s):
 - Exactly what happened, and at what times?
 - What could have been done to prevent the incident?
 - How well did the staff and management perform while dealing with the incident?
 - Were the documented procedures followed? Were they adequate?
 - What information was needed sooner?
 - Were any steps or actions taken that might have inhibited the recovery?
 - What would the staff and management do differently the next time a similar incident occurs?
 - How could information sharing with other organizations be improved?
 - What corrective actions can prevent similar incidents in the future?
 - What precursors or indicators should be watched for in the future to detect similar incidents?
 - What additional tools or resources are needed to detect, analyze, and mitigate future incidents?

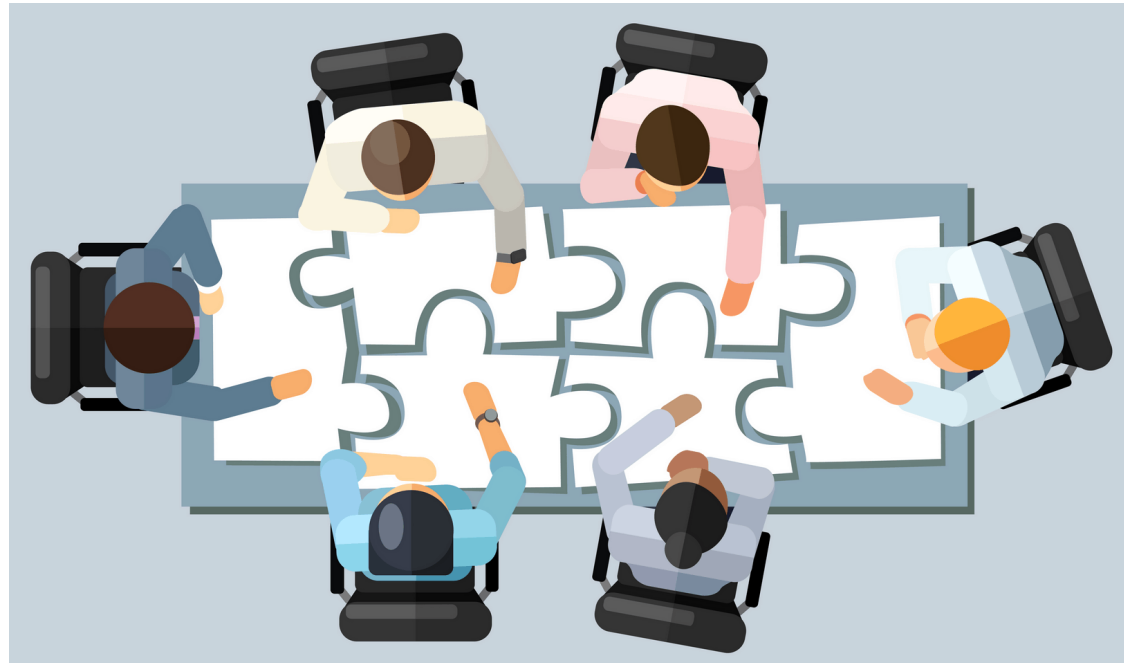


Key Incident Management Personnel & Process



Tabletop Exercises

- Many organizations take advantage of tabletop (simulated) exercises to further test their capabilities.
- These tabletop exercises are an opportunity to **practice** and also **perform gap analysis**.

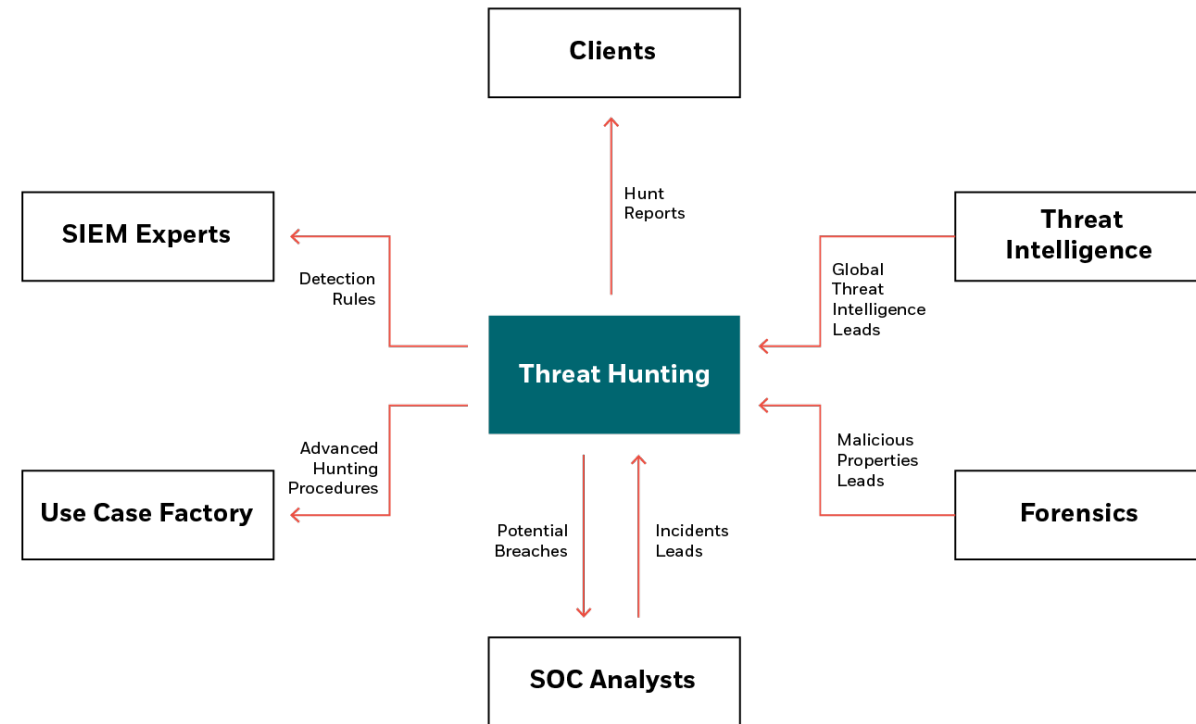


Topics

- Security Operations (SecOps)
- Incident Response
- Threat Hunting
- Digital Forensic Analysis

What is Threat Hunting?

- Threat hunting is a **proactive** and **iterative** approach in cybersecurity, designed to detect and mitigate threats that evade existing security measures.
- The primary goal of threat hunting is to identify and neutralize **sophisticated threats** before they can execute full-scale attacks or exfiltrate sensitive data.

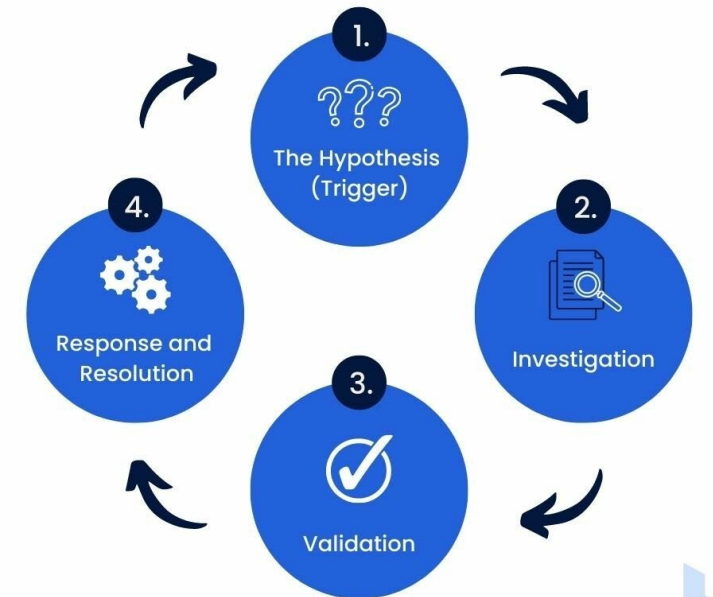


<https://www.cyberproof.com/>

The Threat Hunting Process

1. **Hypothesize:** Develop a hypothesis about where attacker activity may exist
 - Example: “*Could there be undetected lateral movement happening in our network?*”
2. **Collect Data:** Gather evidence (logs, traffic, endpoints)
3. **Analyze:** Look for anomalies or attack signs
4. **Validate:** Confirm real threats vs noise
 - Identify tactics, techniques, and procedures (TTPs) matching attacker behaviors (MITRE ATT&CK is often used here).
5. **Respond:** Take action, learn, and hunt better next time

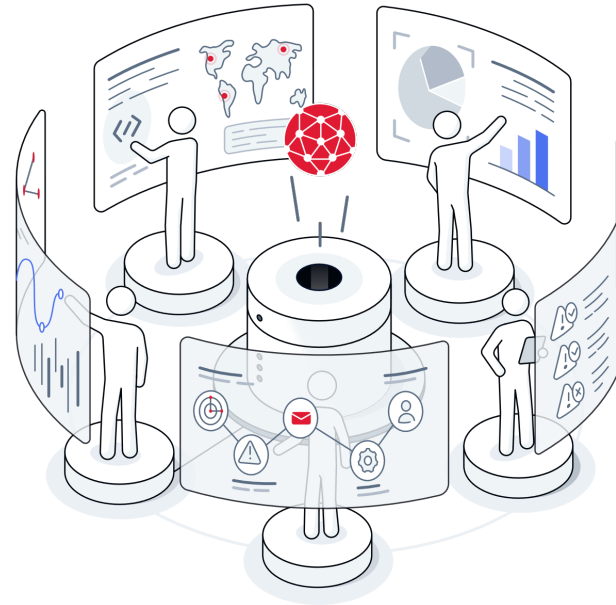
4 STEPS OF CYBER THREAT HUNTING



WWW.BITLYFT.COM/RESOURCES

Threat Intelligence

- Threat intelligence is the proactive **collection**, **analysis**, and **sharing of information** about potential or current cyber threats that could harm an organization's systems, data, or operations.



Threat Intelligence

- It answers:
 - Who the **attackers** are (threat actors)
 - What **methods** they use (attack techniques and malware)
 - What **vulnerabilities** do they exploit
 - What **indicators** can you monitor for (like suspicious IP addresses, domains, file hashes)
 - What **defenses** should you strengthen based on real-world trends



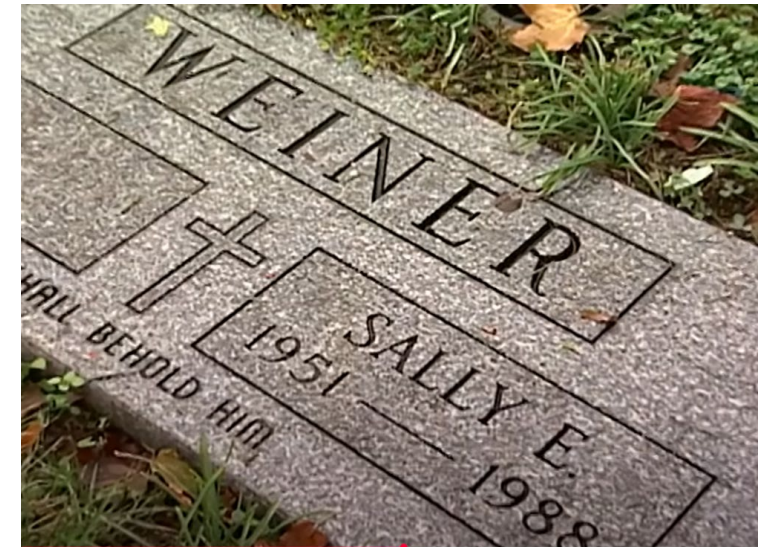
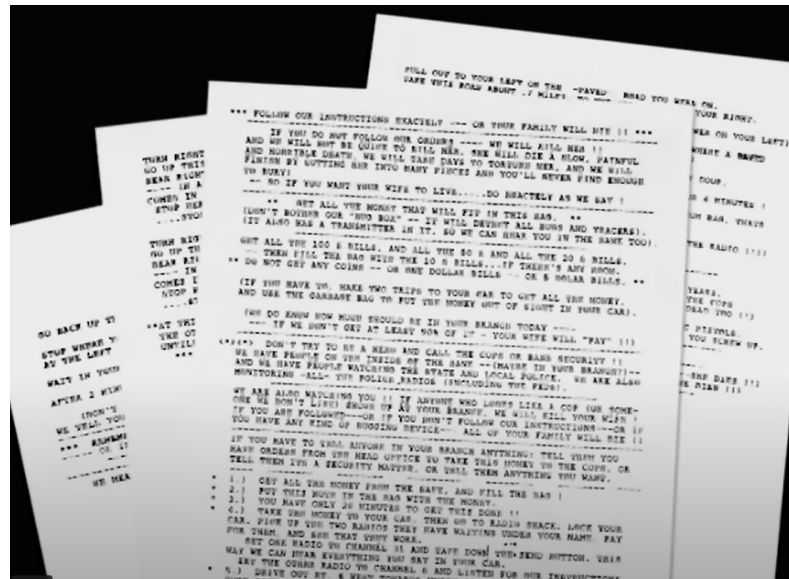
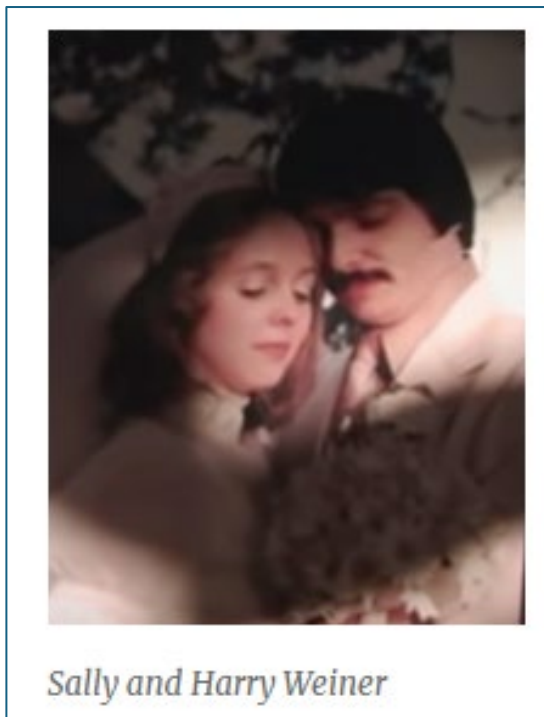
<https://any.run/>

Topics

- Security Operations (SecOps)
- Incident Response
- Threat Hunting
- Digital Forensic Analysis

Commonwealth v. Copenhefer (1991) /1

- The case involved the kidnapping and murder of Sally Weiner, where investigators recovered incriminating documents from the defendant's computer, including files he believed had been deleted.



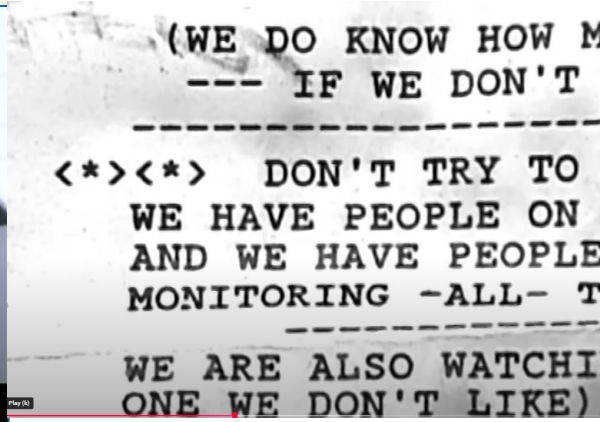
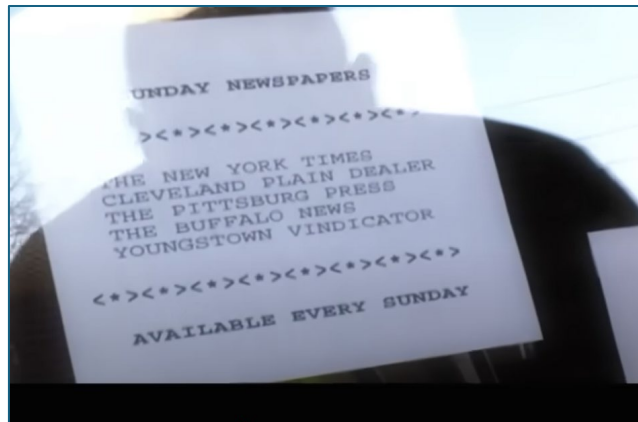
Source: Forensic Files - Season 9, Episode 29 - The Stake-Out

Developing Cybersecurity Programs and Policies in an AI-Driven World – 4th Edition

Santos © 2024

Commonwealth v. Copenhefer (1991) /2

- The defendant argued that retrieving these deleted files violated his privacy rights, but the Pennsylvania Supreme Court ruled that the evidence was admissible.
- Police do not need a second warrant to retrieve deleted data from a lawfully seized computer, just as they can decipher a coded diary or enhance indented writing on a seized pad.



Commonwealth v. Copenhefer (1991) /3

- The court accepted digital evidence as part of the overall body of evidence, reinforcing the role of computer forensics in supporting criminal prosecutions.
- The case became an important early digital forensics precedent, demonstrating that deleted computer files can be recovered and used as evidence in court.



Convicted Killer Copenhefer Dies

Tuesday, January 15th 2013, 2:14 PM EST
Updated: Tuesday, January 22nd 2013, 2:14 PM EST



One of two local inmates on Pennsylvania's death row is dead. David Copenhefer, 65, died Sunday of natural causes at the state prison in Greene County.

Copenhefer was sentenced to death by an Erie County jury for the 1988 kidnapping and murder of Sally Weiner, the wife of a Corry banker. It was part of a scheme by Copenhefer to extort money.

Computer type led to suspect

By Michael A. Fuoco
and Bill Moushey
Post-Gazette Staff Writers

CORRY, Pa. — The typeface of a computer printer led to the arrest of Erie County bookstore owner in the kidnapping of a banker's wife who was later slain, the suspect's wife said yesterday.

The typeface matched that of a note demanding ransom for the return of Sally Weiner, abducted Friday from a shopping plaza shared by the suspect's store and the victim's husband's bank, said David C. Copenhefer's wife, Pat.

She said authorities also told her that her husband had been charged because they found an "an abduction plan and map" Monday in the family's trash.

Nevertheless, Pat Copenhefer said she believes that her husband is innocent.

"David is not the kind of man to do anything like this. He's kind and generous. He would do anything for anybody. He has done a lot of things anonymously to help other people. This is 180 degrees off the mark," she said.

Copenhefer, owner of Corry Books & Cards, was arrested Monday in his Wayne Township

"David is not the kind of man to do anything like this. He's kind and generous. He would do anything for anybody. This is 180 degrees off the mark."

— Pat Copenhefer

home, just north of Corry, on charges of kidnapping, criminal attempt to commit robbery and criminal attempt to commit theft by extortion in the disappearance of Sally Weiner, 37, of Corry.

Weiner's husband, Harry, manages the Pennbank Branch in Corry Plaza, where Copenhefer's store is also located.

Weiner disappeared Friday after apparently being lured to the shopping plaza on the pretext

that a civic tribute was being planned for her husband.

There was an extortion attempt made, and Harry Weiner tried to comply, but no one appeared to collect the money.

Sally Weiner's body, clad in the clothes she had worn Friday, was found Sunday morning in Wayne Township by a farmer checking his fences. She had been shot once in the back of the head and her purse was missing.

No one has been charged in her death.

Pat Copenhefer, said that between the time Weiner was abducted and the time her body was found, David Copenhefer, her husband of 18 years, was either with her, with their 9-year-old son, Paul, or on a business trip to Erie.

"From what he told me, he is able to account for his whereabouts," Pat Copenhefer said.

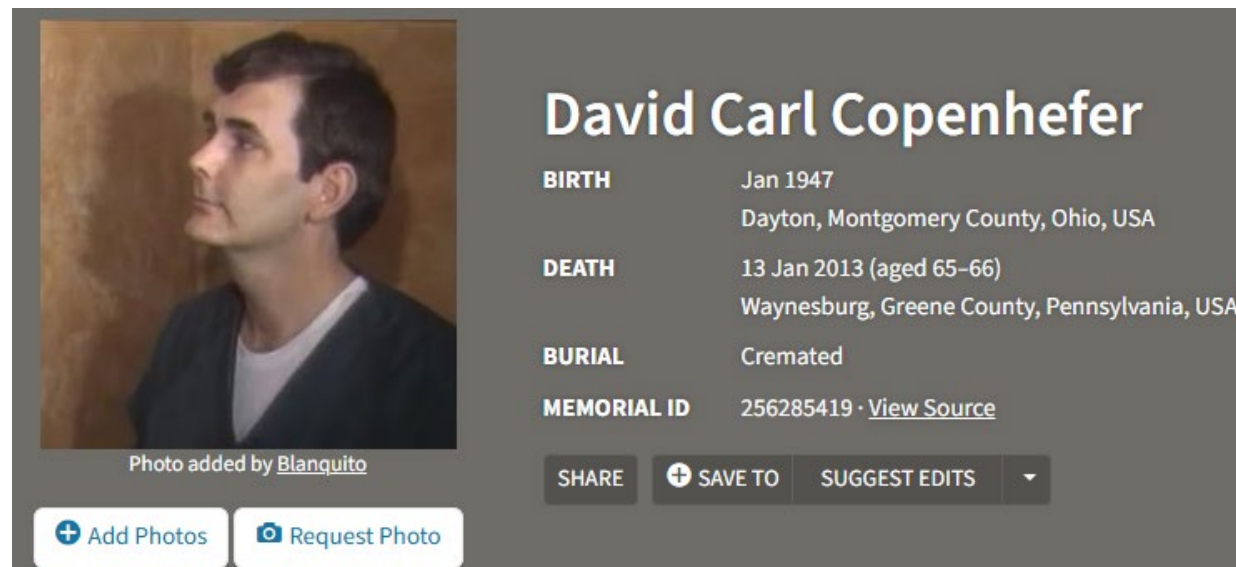
"According to the FBI, he wasn't where he said he was."

Earlier news reports that the Copenhefers were having financial difficulties and had a loan turned down by Pennbank are untrue, she said.

CONTINUED ON PAGE 3

Commonwealth v. Copenhefer (1991) /4

- **Sentence:** Death penalty. The jury found that the victim was held for ransom and that the murder occurred during the commission of a felony, while finding no mitigating circumstances. Pennsylvania courts subsequently upheld both the conviction and the death sentence.
- spent more than 20 years on death row while pursuing appeals, he **died (64 yo) of natural causes on January 13, 2013**, at the State Correctional Institution at Greene in Pennsylvania.



Commonwealth v. Copenhefer



https://www.youtube.com/watch?v=qEkHKe3TfQQ&t=1s&ab_channel=FilmRiseTrueCrime

What is Digital Forensics?

- Digital forensics is the application of science to the identification, collection, examination, and analysis of data while preserving the integrity of the information.

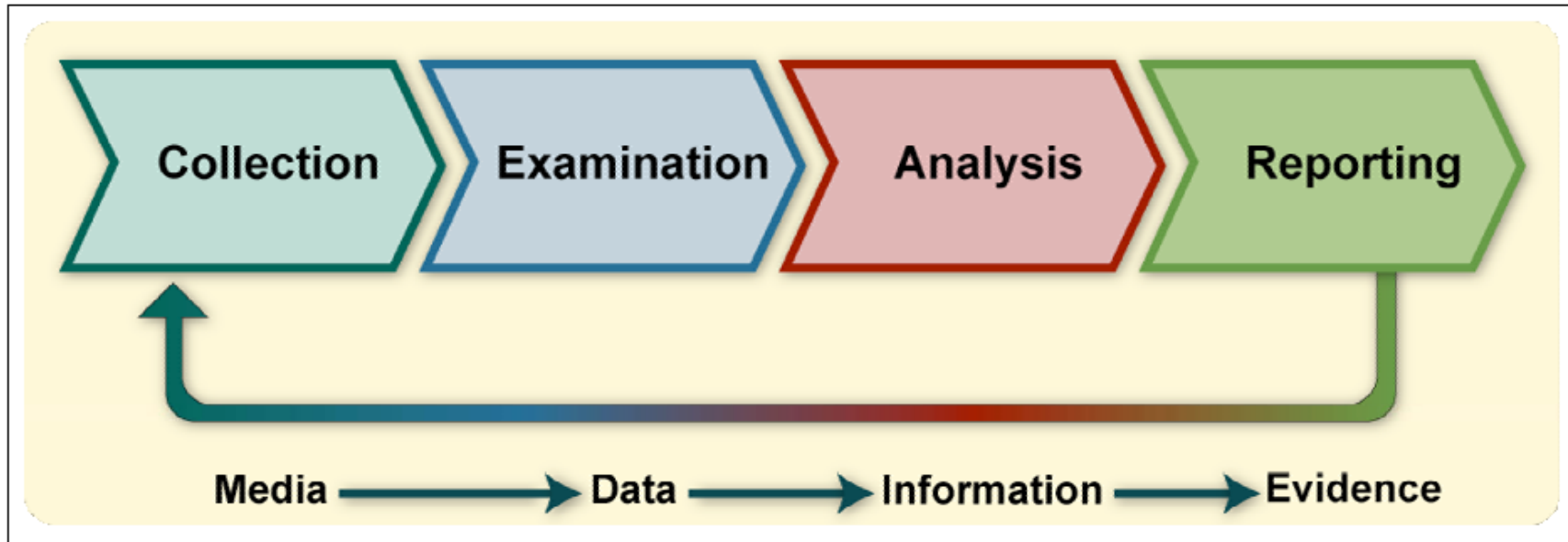
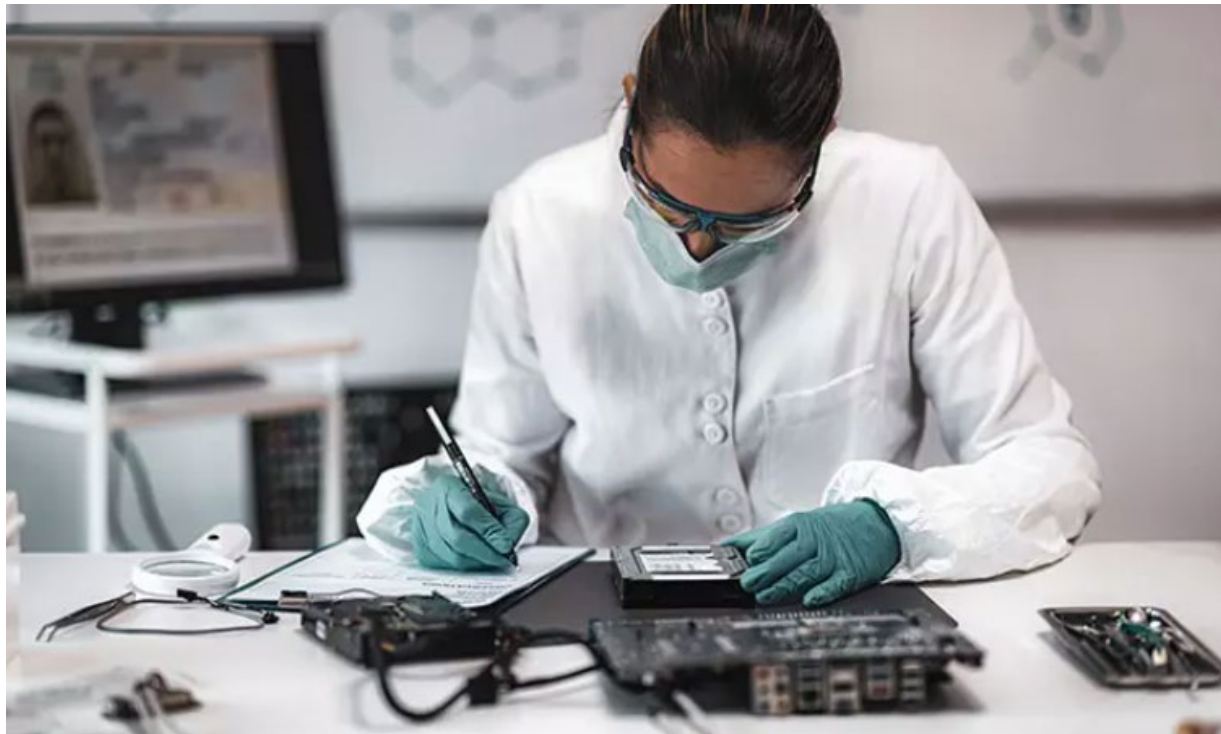


Figure 3-1. Forensic Process

NIST SP 800-86

Why Digital Forensics?

- In addition to reconstructing **security incidents, digital forensic techniques can be used for investigating crimes and internal policy violations**, troubleshooting operational problems, and recovering from accidental system damage.



Tools of the Trade - Digital Forensics

- Forensic tools and techniques are often used to find the root cause of an incident or to uncover facts.



Digital Forensic Evidence

- Digital forensic evidence is information in digital form found on a wide range of endpoints, servers, and network devices—basically, any information that can be processed by a computing device or stored on other media.



Imaging Process

- The imaging process is intended to copy all blocks of data from the computing device to the forensics professional evidentiary system.
- This is sometimes referred to as a “**physical copy**” of all data, as distinct from a “logical copy,” which is a copy of only what a user would normally see.
- Logical copies do not capture all the data, making a full bit-for-bit copy is the preferred forensic process. The file created on the target device is called a **forensic image file**.

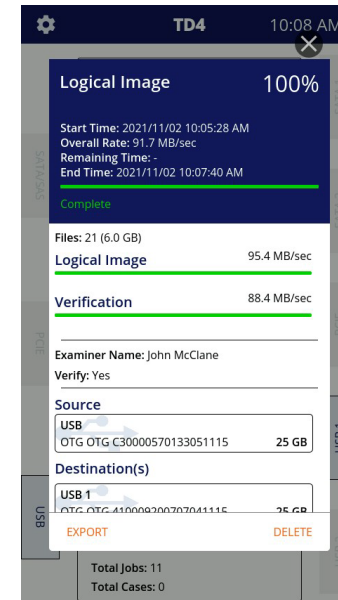


Write Blocker

- To prevent or minimize contamination of the suspect's source device, you can use different tools, such as a piece of hardware called a **write blocker**, on the specific device to copy all the data (or an image of the system).



Accelerate the pace of forensic investigations
with OpenText Forensic TD4



Chain of Custody /1

- Chain of custody is the way you document and preserve evidence from the time that you start the cyber forensics investigation to the time the evidence is presented in court.
- Transporting evidence to a forensics lab or any other place, including a courthouse, has to be done very carefully.
- It is critical that the chain of custody be maintained during transport.

[illegible]

Chain of Custody /2

- It is extremely important to be able to show clear documentation of the following:
 - How the evidence was collected
 - When it was collected
 - How it was transported
 - How it was tracked
 - How it was stored
 - Who had access to the evidence and how it was accessed

Authorization for Evidence Disposal
This item is no longer needed as evidence and is authorized for disposal through the following method: ☐ Return to Owner ☐ Destruction ☐ Donation ☐ Other _____
Release By: _____ Signature: _____ Date: _____
Witness to Evidence Disposal
I, _____, witnessed on the ____ day of ____ 20__ the disposal of this item as performed by _____ in my presence.
Witness: _____ Signature: _____ Date: _____
Evidence Release to Lawful Owner
This item is no longer needed as evidence and has been released by me, _____, to its lawful owner
Owner _____
Address: _____
Telephone Number: (____) _____
Signature: _____ Date: _____

Topics

- SecOps
- Incident Response
- Threat Hunting
- Digital Forensic Analysis

Summary

- The right time to develop an incident response plan is before an incident occurs
- Types of incidents include intentional unauthorized access or use, DoS attacks, malware, and inappropriate usage
- Severity levels can be describes as Level 1, 2, or 3
- Employees should report all actual and suspected incidents
- An incident response plan (IRP) is a roadmap of reporting, responding, and recovery actions
- The NIST incident response process is Preparation; Detection and Analysis; Containment, Eradication, and Recovery; and Post-Incident Activity

In Practice

Incident Definition Policy

Synopsis: Organizational criteria pertaining to an information security incident will be defined.

Policy Statement:

- An information security incident is an event that has the potential to adversely impact our company, our clients, our business partners, and/or the public at large.
- An information security incident is defined as the following:
 - Actual or suspected unauthorized access to, compromise of, acquisition of, or modification of protected client or employee data, including but not limited to:
 - Personal identification numbers, such as Social Insurance Numbers (SINs), passport numbers, and driver's license numbers
 - Financial account or credit card information, including account numbers, card numbers, expiration dates, cardholder names, and service codes
 - Health care/medical information
- An actual or suspected event that has the capacity to disrupt the services provided to our clients.
- Actual or suspected unauthorized access to, compromise of, acquisition of, or modification of company intellectual property.
- An actual or suspected event that has the capacity to disrupt the company's ability to provide internal computing and network services.
- An actual or suspected event that is in violation of legal or statutory requirements.
- An actual or suspected event not defined above that warrants incident classification as determined by management.
- All employees, contractors, consultants, vendors, and business partners are required to report known or suspected information security incidents.
- This policy applies equally to internal and third-party incidents.

In Practice

Information Security Incident Classification Policy

Synopsis: Classify incidents by severity and assigned response and notification requirements.

Policy Statement:

- Incidents are to be classified by severity relative to the impact they have on an organization. If there is ever a question as to which level is appropriate, the company must err on the side of caution and assign the higher severity level.
- Level 1 incidents are defined as those that could cause significant harm to the business, customers, or the public and/or are in violation of corporate law, regulation, or contractual obligation:
 - Level 1 incidents must be responded to immediately upon report.
 - The Chief Executive Officer, Chief Operating Officer, legal counsel, and Chief Information Security Officer must be informed of Level 1 incidents.
- Level 2 incidents are defined as a compromise of or unauthorized access to noncritical systems or information; detection of a precursor to a focused attack; a believed threat of an imminent attack; or any act that is a potential violation of law, regulation, or contractual obligation:
 - Level 2 incidents must be responded to within four hours.
 - The Chief Operating Officer, legal counsel, and Chief Information Security Officer must be informed of Level 2 incidents.
- Level 3 incidents are defined as situations that can be contained and resolved by the information system custodian, data/process owner, or HR personnel. There is no evidence or suspicion of harm to customer or proprietary information, processes, or services:
 - Level 3 incidents must be responded to within 24 business hours.
 - The Information Security Officer must be informed of Level 3 incidents.

Evidence Handling and Use Policy

Synopsis: The organization will ensure that evidence is handled in accordance with legal requirements.

Policy Statement:

- All evidence, logs, and data associated with the incident must be handled as follows:
 - All evidence, logs, and data associated with the incident must be labeled.
 - All evidence, logs, and data associated with the incident should be placed in tamper-resistant containers, grouped together, and put in a limited access location.
- All evidence handling must be recorded on a chain of custody form.
- Unless otherwise instructed by legal counsel or law enforcement officials, all internal digital evidence should be handled in accordance with the procedures described in *Electronic Crime Scene Investigation: A Guide for First Responders*, 2nd edition, from the U.S. Department of Justice, National Institute of Justice (2008). If this is not possible, deviations must be noted.
- Unless otherwise instructed by legal counsel or law enforcement officials, subsequent internal forensic investigation and analysis should follow the guidelines provided in *Forensic Examination of Digital Evidence: A Guide for Law Enforcement* from the U.S. Department of Justice, National Institute of Justice (2004). If this is not possible, deviations must be noted.
- Executive management and the designated incident handler have the authority to engage outside expertise for forensic evidence handling investigation and analysis.
- Exceptions to this policy can be authorized only by legal counsel.

Data Breach Reporting and Notification Policy

Synopsis: The organization will ensure compliance with all applicable laws, regulations, and contractual obligations, timely communications with customers, and internal support for the process.

Policy Statement:

- It is the intent of the company to comply with all information security breach–related laws, regulations, and contractual obligations.
- Executive management has the authority to engage outside expertise for legal counsel, crisis management, PR, and communications.
- Affected customer and business partners will be notified as quickly as possible of a suspected or known compromise of personal information. The company will provide regular updates as more information becomes known.
- Based on applicable laws, legal counsel in collaboration with the Chief Executive Officer will make the determination regarding the scope and content of customer notification.
- Legal counsel and the marketing/PR department will collaborate on all internal and external notifications and communications. All publications must be authorized by executive management.
- Customer Service must staff appropriately to meet the anticipated demand for additional information.
- The Chief Operating Officer is the official spokesperson for the organization. In their absence, the legal counsel will function as the official spokesperson.